



CCNA Cybersecurity Operations

Companion Guide



CCNA Cybersecurity Operations Companion Guide

Cisco Press

CCNA Cybersecurity Operations Companion Guide

Copyright © 2018 Cisco Systems, Inc.

Published by:
Cisco Press

All rights reserved. No part of this book may be reproduced or transmitted in any form or by any means, electronic or mechanical, including photocopying, recording, or by any information storage and retrieval system, without written permission from the publisher, except for the inclusion of brief quotations in a review.

Library of Congress Control Number: 2018939878

ISBN-13: 978-1-58713-439-5

ISBN-10: 1-58713-439-X

Warning and Disclaimer

This book is designed to provide information about the Cisco Networking Academy CCNA Cybersecurity Operations course. Every effort has been made to make this book as complete and as accurate as possible, but no warranty or fitness is implied.

The information is provided on an “as is” basis. The authors, Cisco Press, and Cisco Systems, Inc. shall have neither liability nor responsibility to any person or entity with respect to any loss or damages arising from the information contained in this book or from the use of the discs or programs that may accompany it.

The opinions expressed in this book belong to the author and are not necessarily those of Cisco Systems, Inc.

Editor-in-Chief
Mark Taub

**Alliances Manager,
Cisco Press**
Arezou Gol

Executive Editor
Mary Beth Ray

Managing Editor
Sandra Schroeder

Development Editor
Ellie C. Bru

Senior Project Editor
Tonya Simpson

Copy Editor
Bill McManus

Technical Editor
Patrick Gargano

Editorial Assistant
Vanessa Evans

Cover Designer
Chuti Prasertsith

Composition
codemantra

Indexer
Lisa Stumpf

Proofreader
Jeanine Furino

This book is part of the Cisco Networking Academy® series from Cisco Press. The products in this series support and complement the Cisco Networking Academy curriculum. If you are using this book outside the Networking Academy, then you are not preparing with a Cisco trained and authorized Networking Academy provider.

For more information on the Cisco Networking Academy or to locate a Networking Academy, Please visit www.netacad.com



Trademark Acknowledgments

All terms mentioned in this book that are known to be trademarks or service marks have been appropriately capitalized. Cisco Press or Cisco Systems, Inc., cannot attest to the accuracy of this information. Use of a term in this book should not be regarded as affecting the validity of any trademark or service mark.

Special Sales

For information about buying this title in bulk quantities, or for special sales opportunities (which may include electronic versions; custom cover designs; and content particular to your business, training goals, marketing focus, or branding interests), please contact our corporate sales department at corpsales@pearsoned.com or (800) 382-3419.

For government sales inquiries, please contact governmentsales@pearsoned.com.

For questions about sales outside the U.S., please contact intlcs@pearson.com.

Feedback Information

At Cisco Press, our goal is to create in-depth technical books of the highest quality and value. Each book is crafted with care and precision, undergoing rigorous development that involves the unique expertise of members from the professional technical community.

Readers' feedback is a natural continuation of this process. If you have any comments regarding how we could improve the quality of this book, or otherwise alter it to better suit your needs, you can contact us through email at feedback@ciscopress.com. Please make sure to include the book title and ISBN in your message.

We greatly appreciate your assistance.



Americas Headquarters
Cisco Systems, Inc.
San Jose, CA

Asia Pacific Headquarters
Cisco Systems (USA) Pte. Ltd.
Singapore

Europe Headquarters
Cisco Systems International BV Amsterdam,
The Netherlands

Cisco has more than 200 offices worldwide. Addresses, phone numbers, and fax numbers are listed on the Cisco Website at www.cisco.com/go/offices.

Cisco and the Cisco logo are trademarks or registered trademarks of Cisco and/or its affiliates in the U.S. and other countries. To view a list of Cisco trademarks, go to this URL: www.cisco.com/go/trademarks. Third party trademarks mentioned are the property of their respective owners. The use of the word partner does not imply a partnership relationship between Cisco and any other company. (1110R)

About the Contributing Author

Allan Johnson entered the academic world in 1999 after 10 years as a business owner/operator to dedicate his efforts to his passion for teaching. He holds both an MBA and an M.Ed in training and development. He taught CCNA courses at the high school level for seven years and has taught both CCNA and CCNP courses at Del Mar College in Corpus Christi, Texas. In 2003, Allan began to commit much of his time and energy to the CCNA Instructional Support Team providing services to Networking Academy instructors worldwide and creating training materials. He now works full time for Cisco Networking Academy as Curriculum Lead.

Contents at a Glance

	Introduction	xxiv
Chapter 1	Cybersecurity and the Security Operations Center	1
Chapter 2	Windows Operating System	19
Chapter 3	Linux Operating System	71
Chapter 4	Network Protocols and Services	115
Chapter 5	Network Infrastructure	235
Chapter 6	Principles of Network Security	295
Chapter 7	Network Attacks: A Deeper Look	331
Chapter 8	Protecting the Network	375
Chapter 9	Cryptography and the Public Key Infrastructure	399
Chapter 10	Endpoint Security and Analysis	455
Chapter 11	Security Monitoring	501
Chapter 12	Intrusion Data Analysis	541
Chapter 13	Incident Response and Handling	581
Appendix A	Answers to the “Check Your Understanding” Questions	619
	Glossary	635
	Index	655

Contents

Introduction xxiv

Chapter 1 Cybersecurity and the Security Operations Center 1

Objectives 1

Key Terms 1

Introduction (1.0) 2

The Danger (1.1) 2

War Stories (1.1.1) 2

Hijacked People (1.1.1.1) 2

Ransomed Companies (1.1.1.2) 3

Nations (1.1.1.3) 3

Threat Actors (1.1.2) 4

Amateurs (1.1.2.1) 4

Hacktivists (1.1.2.2) 4

Financial Gain (1.1.2.3) 4

Trade Secrets and Global Politics (1.1.2.4) 4

How Secure Is the Internet of Things? (1.1.2.5) 4

Threat Impact (1.1.3) 5

PII and PHI (1.1.3.1) 5

Lost Competitive Advantage (1.1.3.2) 6

Politics and National Security (1.1.3.3) 6

Fighters in the War Against Cybercrime (1.2) 7

The Modern Security Operations Center (1.2.1) 7

Elements of an SOC (1.2.1.1) 7

People in the SOC (1.2.1.2) 8

Process in the SOC (1.2.1.3) 8

Technologies in the SOC (1.2.1.4) 9

Enterprise and Managed Security (1.2.1.5) 10

Security vs. Availability (1.2.1.6) 11

Becoming a Defender (1.2.2) 11

Certifications (1.2.2.1) 12

Further Education (1.2.2.2) 12

Sources of Career Information (1.2.2.3) 13

Getting Experience (1.2.2.4) 13

Summary (1.3) 15

Practice 15

Check Your Understanding 16

CHAPTER 2 Windows Operating System 19

Objectives 19

Key Terms 19

Introduction (2.0) 21

Windows Overview (2.1) 21

Windows History (2.1.1) 21

Disk Operating System (2.1.1.1) 21

Windows Versions (2.1.1.2) 23

Windows GUI (2.1.1.3) 24

Operating System Vulnerabilities (2.1.1.4) 26

Windows Architecture and Operations (2.1.2) 27

Hardware Abstraction Layer (2.1.2.1) 27

User Mode and Kernel Mode (2.1.2.2) 28

Windows File Systems (2.1.2.3) 28

Windows Boot Process (2.1.2.4) 31

Windows Startup and Shutdown (2.1.2.5) 33

Processes, Threads, and Services (2.1.2.6) 36

Memory Allocation and Handles (2.1.2.7) 38

The Windows Registry (2.1.2.8) 38

Windows Administration (2.2) 41

Windows Configuration and Monitoring (2.2.1) 41

Run as Administrator (2.2.1.1) 41

Local Users and Domains (2.2.1.2) 42

CLI and PowerShell (2.2.1.3) 44

Windows Management Instrumentation (2.2.1.4) 46

The net Command (2.2.1.5) 47

Task Manager and Resource Monitor (2.2.1.6) 49

Networking (2.2.1.7) 51

Accessing Network Resources (2.2.1.8) 56

Windows Server (2.2.1.9) 56

Windows Security (2.2.2) 58

The netstat Command (2.2.2.1) 58

Event Viewer (2.2.2.2) 59

Windows Update Management (2.2.2.3) 60

Local Security Policy (2.2.2.4) 61

Windows Defender (2.2.2.5) 63

Windows Firewall (2.2.2.6) 64

Summary (2.3) 66

Practice 67

Check Your Understanding 68

Chapter 3 Linux Operating System 71

Objectives 71

Key Terms 71

Introduction (3.0) 73

Linux Overview (3.1) 73

Linux Basics (3.1.1) 73

What is Linux? (3.1.1.1) 73

The Value of Linux (3.1.1.2) 74

Linux in the SOC (3.1.1.3) 74

Linux Tools (3.1.1.4) 76

Working in the Linux Shell (3.1.2) 76

The Linux Shell (3.1.2.1) 77

Basic Commands (3.1.2.2) 77

File and Directory Commands (3.1.2.3) 79

Working with Text Files (3.1.2.4) 79

The Importance of Text Files in Linux (3.1.2.5) 80

Linux Servers and Clients (3.1.3) 82

*An Introduction to Client-Server Communications
(3.1.3.1) 82*

Servers, Services, and Their Ports (3.1.3.2) 83

Clients (3.1.3.3) 83

Linux Administration (3.2) 84

Basic Server Administration (3.2.1) 84

Service Configuration Files (3.2.1.1) 84

Hardening Devices (3.2.1.2) 88

Monitoring Service Logs (3.2.1.3) 89

The Linux File System (3.2.2) 91

The File System Types in Linux (3.2.2.1) 92

Linux Roles and File Permissions (3.2.2.2) 94

Hard Links and Symbolic Links (3.2.2.3) 96

Linux Hosts (3.3) 97

Working with the Linux GUI (3.3.1) 97

X Window System (3.3.1.1) 98

The Linux GUI (3.3.1.2) 99

Working on a Linux Host (3.3.2) 100

*Installing and Running Applications on a
Linux Host (3.3.2.1) 100*

Keeping the System Up to Date (3.3.2.2) 102

Processes and Forks (3.3.2.3) 102

	<i>Malware on a Linux Host (3.3.2.4)</i>	105
	<i>Rootkit Check (3.3.2.5)</i>	106
	<i>Piping Commands (3.3.2.6)</i>	110
	Summary (3.4)	111
	Practice	112
	Check Your Understanding	112
Chapter 4	Network Protocols and Services	115
	Objectives	115
	Key Terms	115
	Introduction (4.0)	118
	Network Protocols (4.1)	118
	Network Communications Process (4.1.1)	118
	<i>Views of the Network (4.1.1.1)</i>	118
	<i>Client-Server Communications (4.1.1.2)</i>	119
	<i>A Typical Session: Student (4.1.1.3)</i>	119
	<i>A Typical Session: Gamer (4.1.1.4)</i>	120
	<i>A Typical Session: Surgeon (4.1.1.5)</i>	121
	<i>Tracing the Path (4.1.1.6)</i>	121
	Communications Protocols (4.1.2)	123
	<i>What Are Protocols? (4.1.2.1)</i>	123
	<i>Network Protocol Suites (4.1.2.2)</i>	124
	<i>The TCP/IP Protocol Suite (4.1.2.3)</i>	126
	<i>Format, Size, and Timing (4.1.2.4)</i>	128
	<i>Unicast, Multicast, and Broadcast (4.1.2.5)</i>	129
	<i>Reference Models (4.1.2.6)</i>	130
	<i>Three Addresses (4.1.2.7)</i>	131
	<i>Encapsulation (4.1.2.8)</i>	132
	<i>Scenario: Sending and Receiving a Web Page (4.1.2.9)</i>	136
	Ethernet and Internet Protocol (IP) (4.2)	139
	Ethernet (4.2.1)	139
	<i>The Ethernet Protocol (4.2.1.1)</i>	139
	<i>The Ethernet Frame (4.2.1.2)</i>	140
	<i>MAC Address Format (4.2.1.3)</i>	141
	IPv4 (4.2.2)	142
	<i>IPv4 Encapsulation (4.2.2.1)</i>	142
	<i>IPv4 Characteristics (4.2.2.2)</i>	144
	<i>The IPv4 Packet (4.2.2.4)</i>	147
	IPv4 Addressing Basics (4.2.3)	148
	<i>IPv4 Address Notation (4.2.3.1)</i>	148
	<i>IPv4 Host Address Structure (4.2.3.2)</i>	149

IPv4 Subnet Mask and Network Address (4.2.3.3)	151
Subnetting Broadcast Domains (4.2.3.4)	152
Types of IPv4 Addresses (4.2.4)	155
IPv4 Address Classes and Default Subnet Masks (4.2.4.1)	155
Reserved Private Addresses (4.2.4.2)	156
The Default Gateway (4.2.5)	157
Host Forwarding Decision (4.2.5.1)	157
Default Gateway (4.2.5.2)	158
Using the Default Gateway (4.2.5.3)	159
IPv6 (4.2.6)	160
Need for IPv6 (4.2.6.1)	160
IPv6 Size and Representation (4.2.6.2)	161
IPv6 Address Formatting (4.2.6.3)	162
IPv6 Prefix Length (4.2.6.4)	163
Connectivity Verification (4.3)	164
ICMP (4.3.1)	164
ICMPv4 Messages (4.3.1.1)	164
ICMPv6 RS and RA Messages (4.3.1.2)	166
Ping and Traceroute Utilities (4.3.2)	168
Ping: Testing the Local Stack (4.3.2.1)	168
Ping: Testing Connectivity to the Local LAN (4.3.2.2)	169
Ping: Testing Connectivity to Remote Host (4.3.2.3)	170
Traceroute: Testing the Path (4.3.2.4)	172
ICMP Packet Format (4.3.2.5)	175
Address Resolution Protocol (4.4)	176
MAC and IP (4.4.1)	176
Destination on the Same Network (4.4.1.1)	176
Destination on a Remote Network (4.4.1.2)	178
ARP (4.4.2)	179
Introduction to ARP (4.4.2.1)	179
ARP Functions (4.4.2.2)	179
Removing Entries from an ARP Table (4.4.2.6)	181
ARP Tables on Networking Devices (4.4.2.7)	181
ARP Issues (4.4.3)	182
ARP Broadcasts (4.4.3.1)	182
ARP Spoofing (4.4.3.2)	183
The Transport Layer (4.5)	184
Transport Layer Characteristics (4.5.1)	184
Transport Layer Protocol Role in Network Communication (4.5.1.1)	184
Transport Layer Mechanisms (4.5.1.2)	186

<i>TCP Local and Remote Ports (4.5.1.3)</i>	187
<i>Socket Pairs (4.5.1.4)</i>	189
<i>TCP vs. UDP (4.5.1.5)</i>	190
<i>TCP and UDP Headers (4.5.1.6)</i>	194
Transport Layer Operation (4.5.2)	196
<i>TCP Port Allocation (4.5.2.1)</i>	196
<i>A TCP Session Part I: Connection Establishment and Termination (4.5.2.2)</i>	199
<i>A TCP Session Part II: Data Transfer (4.5.2.6)</i>	201
<i>A UDP Session (4.5.2.9)</i>	204
Network Services (4.6)	206
DHCP (4.6.1)	206
<i>DHCP Overview (4.6.1.1)</i>	206
<i>DHCPv4 Message Format (4.6.1.2)</i>	208
DNS (4.6.2)	209
<i>DNS Overview (4.6.2.1)</i>	209
<i>The DNS Domain Hierarchy (4.6.2.2)</i>	210
<i>The DNS Lookup Process (4.6.2.3)</i>	211
<i>DNS Message Format (4.6.2.4)</i>	213
<i>Dynamic DNS (4.6.2.5)</i>	214
<i>The WHOIS Protocol (4.6.2.6)</i>	215
NAT (4.6.3)	216
<i>NAT Overview (4.6.3.1)</i>	216
<i>NAT-Enabled Routers (4.6.3.2)</i>	217
<i>Port Address Translation (4.6.3.3)</i>	218
File Transfer and Sharing Services (4.6.4)	219
<i>FTP and TFTP (4.6.4.1)</i>	219
<i>SMB (4.6.4.2)</i>	220
Email (4.6.5)	222
<i>Email Overview (4.6.5.1)</i>	222
<i>SMTP (4.6.5.2)</i>	223
<i>POP3 (4.6.5.3)</i>	223
<i>IMAP (4.6.5.4)</i>	224
HTTP (4.6.6)	225
<i>HTTP Overview (4.6.6.1)</i>	225
<i>The HTTP URL (4.6.6.2)</i>	227
<i>The HTTP Protocol (4.6.6.3)</i>	227
<i>HTTP Status Codes (4.6.6.4)</i>	228
Summary (4.7)	230
Practice	231
Check Your Understanding	231

Chapter 5 Network Infrastructure 235

Objectives 235

Key Terms 235

Introduction (5.0) 237

Network Communication Devices (5.1) 237

Network Devices (5.1.1) 237

End Devices (5.1.1.1) 237

Routers (5.1.1.3) 238

Router Operation (5.1.1.5) 241

Routing Information (5.1.1.6) 242

Hubs, Bridges, LAN Switches (5.1.1.8) 244

Switching Operation (5.1.1.9) 245

VLANs (5.1.1.11) 247

STP (5.1.1.12) 248

Multilayer Switching (5.1.1.13) 253

Wireless Communications (5.1.2) 254

Protocols and Features (5.1.2.2) 254

Wireless Network Operations (5.1.2.3) 256

The Client to AP Association Process (5.1.2.4) 258

Wireless Devices: AP, LWAP, WLC (5.1.2.6) 261

Network Security Infrastructure (5.2) 262

Security Devices (5.2.1) 262

Firewalls (5.2.1.2) 262

Firewall Type Descriptions (5.2.1.3) 263

Packet Filtering Firewalls (5.2.1.4) 265

Stateful Firewalls (5.2.1.5) 266

Next-Generation Firewalls (5.2.1.6) 266

Intrusion Protection and Detection Devices (5.2.1.8) 267

*Advantages and Disadvantages of IDS and IPS
(5.2.1.9) 268*

Types of IPS (5.2.1.10) 269

Specialized Security Appliances (5.2.1.11) 271

Security Services (5.2.2) 272

Traffic Control with ACLs (5.2.2.2) 272

ACLs: Important Features (5.2.2.3) 273

SNMP (5.2.2.5) 274

NetFlow (5.2.2.6) 275

Port Mirroring (5.2.2.7) 276

Syslog Servers (5.2.2.8) 277

NTP (5.2.2.9) 277

AAA Servers (5.2.2.10) 279

VPN (5.2.2.11) 280

Network Representations (5.3) 282

Network Topologies (5.3.1) 282

*Overview of Network Components (5.3.1.1) 282**Physical and Logical Topologies (5.3.1.2) 283**WAN Topologies (5.3.1.3) 285**LAN Topologies (5.3.1.4) 285**The Three-Layer Network Design Model (5.3.1.5) 286**Common Security Architectures (5.3.1.7) 288***Summary (5.4) 291****Practice 292****Check Your Understanding 292****Chapter 6 Principles of Network Security 295****Objectives 295****Key Terms 295****Introduction (6.0) 297****Attackers and Their Tools (6.1) 297**

Who Is Attacking Our Network (6.1.1) 297

*Threat, Vulnerability, and Risk (6.1.1.1) 297**Hacker vs. Threat Actor (6.1.1.2) 298**Evolution of Threat Actors (6.1.1.3) 299**Cybercriminals (6.1.1.4) 300**Cybersecurity Tasks (6.1.1.5) 300**Cyber Threat Indicators (6.1.1.6) 300*

Threat Actor Tools (6.1.2) 301

*Introduction of Attack Tools (6.1.2.1) 301**Evolution of Security Tools (6.1.2.2) 302**Categories of Attacks (6.1.2.3) 304***Common Threats and Attacks (6.2) 305**

Malware (6.2.1) 305

*Types of Malware (6.2.1.1) 305**Viruses (6.2.1.2) 306**Trojan Horses (6.2.1.3) 306**Trojan Horse Classification (6.2.1.4) 307**Worms (6.2.1.5) 307**Worm Components (6.2.1.6) 308**Ransomware (6.2.1.7) 309**Other Malware (6.2.1.8) 310**Common Malware Behaviors (6.2.1.9) 310*

Common Network Attacks (6.2.2)	311
<i>Types of Network Attacks (6.2.2.1)</i>	311
<i>Reconnaissance Attacks (6.2.2.2)</i>	312
<i>Sample Reconnaissance Attacks (6.2.2.3)</i>	312
<i>Access Attacks (6.2.2.4)</i>	314
<i>Types of Access Attacks (6.2.2.5)</i>	315
<i>Social Engineering Attacks (6.2.2.6)</i>	317
<i>Phishing Social Engineering Attacks (6.2.2.7)</i>	318
<i>Strengthening the Weakest Link (6.2.2.8)</i>	319
<i>Denial-of-Service Attacks (6.2.2.10)</i>	319
<i>DDoS Attacks (6.2.2.11)</i>	320
<i>Example DDoS Attack (6.2.2.12)</i>	321
<i>Buffer Overflow Attack (6.2.2.13)</i>	322
<i>Evasion Methods (6.2.2.14)</i>	323

Summary (6.3) 325

Practice 327

Check Your Understanding 327

Chapter 7 Network Attacks: A Deeper Look 331

Objectives 331

Key Terms 331

Introduction (7.0) 332

Network Monitoring and Tools (7.1) 332

Introduction to Network Monitoring (7.1.1)	332
<i>Network Security Topology (7.1.1.1)</i>	332
<i>Monitoring the Network (7.1.1.2)</i>	333
<i>Network TAPs (7.1.1.3)</i>	333
<i>Traffic Mirroring and SPAN (7.1.1.4)</i>	334
Introduction to Network Monitoring Tools (7.1.2)	335
<i>Network Security Monitoring Tools (7.1.2.1)</i>	335
<i>Network Protocol Analyzers (7.1.2.2)</i>	335
<i>NetFlow (7.1.2.3)</i>	337
<i>SIEM (7.1.2.4)</i>	338
<i>SIEM Systems (7.1.2.5)</i>	339

Attacking the Foundation (7.2) 340

IP Vulnerabilities and Threats (7.2.1)	340
<i>IPv4 and IPv6 (7.2.1.1)</i>	340
<i>The IPv4 Packet Header (7.2.1.2)</i>	340
<i>The IPv6 Packet Header (7.2.1.3)</i>	342
<i>IP Vulnerabilities (7.2.1.4)</i>	343
<i>ICMP Attacks (7.2.1.5)</i>	343
<i>DoS Attacks (7.2.1.6)</i>	345

<i>Amplification and Reflection Attacks (7.2.1.7)</i>	346
<i>DDoS Attacks (7.2.1.8)</i>	347
<i>Address Spoofing Attacks (7.2.1.9)</i>	348
TCP and UDP Vulnerabilities (7.2.2)	350
<i>TCP (7.2.2.1)</i>	350
<i>TCP Attacks (7.2.2.2)</i>	351
<i>UDP and UDP Attacks (7.2.2.3)</i>	353

Attacking What We Do (7.3) 354

IP Services (7.3.1)	354
<i>ARP Vulnerabilities (7.3.1.1)</i>	354
<i>ARP Cache Poisoning (7.3.1.2)</i>	355
<i>DNS Attacks (7.3.1.3)</i>	357
<i>DNS Tunneling (7.3.1.4)</i>	358
<i>DHCP (7.3.1.5)</i>	359
Enterprise Services (7.3.2)	362
<i>HTTP and HTTPS (7.3.2.1)</i>	362
<i>Email (7.3.2.2)</i>	366
<i>Web-Exposed Databases (7.3.2.3)</i>	367

Summary (7.4) 370

Practice 370

Check Your Understanding 371

Chapter 8 Protecting the Network 375

Objectives 375

Key Terms 375

Introduction (8.0) 376

Understanding Defense (8.1) 376

Defense-in-Depth (8.1.1)	376
<i>Assets, Vulnerabilities, Threats (8.1.1.1)</i>	376
<i>Identify Assets (8.1.1.2)</i>	376
<i>Identify Vulnerabilities (8.1.1.3)</i>	377
<i>Identify Threats (8.1.1.4)</i>	378
<i>Security Onion and Security Artichoke Approaches (8.1.1.5)</i>	379
Security Policies (8.1.2)	381
<i>Business Policies (8.1.2.1)</i>	381
<i>Security Policy (8.1.2.2)</i>	381
<i>BYOD Policies (8.1.2.3)</i>	382
<i>Regulatory and Standard Compliance (8.1.2.4)</i>	383

Access Control (8.2) 384

- Access Control Concepts (8.2.1) 384
 - Communications Security: CIA (8.2.1.1) 384*
 - Access Control Models (8.2.1.2) 385*
- AAA Usage and Operation (8.2.2) 385
 - AAA Operation (8.2.2.1) 385*
 - AAA Authentication (8.2.2.2) 386*
 - AAA Accounting Logs (8.2.2.3) 388*

Threat Intelligence (8.3) 390

- Information Sources (8.3.1) 390
 - Network Intelligence Communities (8.3.1.1) 390*
 - Cisco Cybersecurity Reports (8.3.1.2) 392*
 - Security Blogs and Podcasts (8.3.1.3) 392*
- Threat Intelligence Services (8.3.2) 392
 - Cisco Talos (8.3.2.1) 392*
 - FireEye (8.3.2.2) 393*
 - Automated Indicator Sharing (8.3.2.3) 393*
 - Common Vulnerabilities and Exposures Database (8.3.2.4) 393*
 - Threat Intelligence Communication Standards (8.3.2.5) 394*

Summary (8.4) 395

Practice 396

Check Your Understanding Questions 396

Chapter 9 Cryptography and the Public Key Infrastructure 399

Objectives 399

Key Terms 399

Introduction (9.0) 400

Cryptography (9.1) 400

- What Is Cryptography? (9.1.1) 400
 - Securing Communications (9.1.1.1) 400*
 - Cryptology (9.1.1.2) 402*
 - Cryptography: Ciphers (9.1.1.3) 403*
 - Cryptanalysis: Code Breaking (9.1.1.4) 406*
 - Keys (9.1.1.5) 408*
- Integrity and Authenticity (9.1.2) 409
 - Cryptographic Hash Functions (9.1.2.1) 409*
 - Cryptographic Hash Operation (9.1.2.2) 411*
 - MD5 and SHA (9.1.2.3) 411*
 - Hash Message Authentication Code (9.1.2.4) 413*

Confidentiality (9.1.3) 416*Encryption (9.1.3.1) 416**Symmetric Encryption (9.1.3.2) 417**Symmetric Encryption Algorithms (9.1.3.3) 418**Asymmetric Encryption Algorithms (9.1.3.4) 421**Asymmetric Encryption: Confidentiality (9.1.3.5) 423**Asymmetric Encryption: Authentication (9.1.3.6) 425**Asymmetric Encryption: Integrity (9.1.3.7) 426**Diffie-Hellman (9.1.3.8) 428***Public Key Infrastructure (9.2) 429****Public Key Cryptography (9.2.1) 430***Using Digital Signatures (9.2.1.1) 430**Digital Signatures for Code Signing (9.2.1.2) 432**Digital Signatures for Digital Certificates (9.2.1.3) 435***Authorities and the PKI Trust System (9.2.2) 437***Public Key Management (9.2.2.1) 437**The Public Key Infrastructure (9.2.2.2) 438**The PKI Authorities System (9.2.2.3) 439**The PKI Trust System (9.2.2.4) 441**Interoperability of Different PKI Vendors (9.2.2.5) 442**Certificate Enrollment, Authentication, and Revocation
(9.2.2.6) 444***Applications and Impacts of Cryptography (9.2.3) 446***PKI Applications (9.2.3.1) 447**Encrypting Network Transactions (9.2.3.2) 447**Encryption and Security Monitoring (9.2.3.3) 448***Summary (9.3) 450****Practice 451****Check Your Understanding 452****Chapter 10 Endpoint Security and Analysis 455****Objectives 455****Key Terms 455****Introduction (10.0) 456****Endpoint Protection (10.1) 456****Antimalware Protection (10.1.1) 456***Endpoint Threats (10.1.1.1) 456**Endpoint Security (10.1.1.2) 457**Host-Based Malware Protection (10.1.1.3) 459**Network-Based Malware Protection (10.1.1.4) 461**Cisco Advanced Malware Protection (AMP) (10.1.1.5) 462*

Host-Based Intrusion Protection (10.1.2)	463
<i>Host-Based Firewalls (10.1.2.1)</i>	463
<i>Host-Based Intrusion Detection (10.1.2.2)</i>	464
<i>HIDS Operation (10.1.2.3)</i>	465
<i>HIDS Products (10.1.2.4)</i>	466
Application Security (10.1.3)	466
<i>Attack Surface (10.1.3.1)</i>	466
<i>Application Blacklisting and Whitelisting (10.1.3.2)</i>	467
<i>System-Based Sandboxing (10.1.3.3)</i>	469

Endpoint Vulnerability Assessment (10.2) 470

Network and Server Profiling (10.2.1)	470
<i>Network Profiling (10.2.1.1)</i>	470
<i>Server Profiling (10.2.1.2)</i>	471
<i>Network Anomaly Detection (10.2.1.3)</i>	472
<i>Network Vulnerability Testing (10.2.1.4)</i>	473
Common Vulnerability Scoring System (CVSS) (10.2.2)	473
<i>CVSS Overview (10.2.2.1)</i>	473
<i>CVSS Metric Groups (10.2.2.2)</i>	474
<i>CVSS Base Metric Group (10.2.2.3)</i>	475
<i>The CVSS Process (10.2.2.4)</i>	476
<i>CVSS Reports (10.2.2.5)</i>	478
<i>Other Vulnerability Information Sources (10.2.2.6)</i>	479
Compliance Frameworks (10.2.3)	480
<i>Compliance Regulations (10.2.3.1)</i>	480
<i>Overview of Regulatory Standards (10.2.3.2)</i>	480
Secure Device Management (10.2.4)	482
<i>Risk Management (10.2.4.1)</i>	482
<i>Vulnerability Management (10.2.4.3)</i>	484
<i>Asset Management (10.2.4.4)</i>	486
<i>Mobile Device Management (10.2.4.5)</i>	486
<i>Configuration Management (10.2.4.6)</i>	487
<i>Enterprise Patch Management (10.2.4.7)</i>	488
<i>Patch Management Techniques (10.2.4.8)</i>	488
Information Security Management Systems (10.2.5)	491
<i>Security Management Systems (10.2.5.1)</i>	491
<i>ISO-27001 (10.2.5.2)</i>	491
<i>NIST Cybersecurity Framework (10.2.5.3)</i>	493

Summary (10.3) 496

Practice 497

Check Your Understanding 498

Chapter 11 Security Monitoring 501**Objectives 501****Key Terms 501****Introduction (11.0) 502****Technologies and Protocols (11.1) 502**

Monitoring Common Protocols (11.1.1) 502

*Syslog and NTP (11.1.1.1) 502**NTP (11.1.1.2) 503**DNS (11.1.1.3) 504**HTTP and HTTPS (11.1.1.4) 505**Email Protocols (11.1.1.5) 507**ICMP (11.1.1.6) 507*

Security Technologies (11.1.2) 508

*ACLs (11.1.2.1) 508**NAT and PAT (11.1.2.2) 509**Encryption, Encapsulation, and Tunneling (11.1.2.3) 510**Peer-to-Peer Networking and Tor (11.1.2.4) 511**Load Balancing (11.1.2.5) 512***Log Files (11.2) 513**

Types of Security Data (11.2.1) 513

*Alert Data (11.2.1.1) 514**Session and Transaction Data (11.2.1.2) 515**Full Packet Captures (11.2.1.3) 516**Statistical Data (11.2.1.4) 517*

End Device Logs (11.2.2) 518

*Host Logs (11.2.2.1) 518**Syslog (11.2.2.2) 520**Server Logs (11.2.2.3) 521**Apache HTTP Server Access Logs (11.2.2.4) 522**IIS Access Logs (11.2.2.5) 523**SIEM and Log Collection (11.2.2.6) 525*

Network Logs (11.2.3) 526

*Tcpdump (11.2.3.1) 526**NetFlow (11.2.3.2) 527**Application Visibility and Control (11.2.3.3) 529**Content Filter Logs (11.2.3.4) 530**Logging from Cisco Devices (11.2.3.5) 531**Proxy Logs (11.2.3.6) 532**NextGen IPS (11.2.3.7) 535***Summary (11.3) 537****Practice 538****Check Your Understanding 538**

Chapter 12 Intrusion Data Analysis 541

Objectives 541

Key Terms 541

Introduction (12.0) 542

Evaluating Alerts (12.1) 542

Sources of Alerts (12.1.1) 542

Security Onion (12.1.1.1) 542

Detection Tools for Collecting Alert Data (12.1.1.2) 543

Analysis Tools (12.1.1.3) 544

Alert Generation (12.1.1.4) 544

Rules and Alerts (12.1.1.5) 546

Snort Rule Structure (12.1.1.6) 547

Overview of Alert Evaluation (12.1.2) 550

The Need for Alert Evaluation (12.1.2.1) 550

Evaluating Alerts (12.1.2.2) 551

*Deterministic Analysis and Probabilistic Analysis
(12.1.2.3) 552*

Working with Network Security Data (12.2) 554

A Common Data Platform (12.2.1) 554

ELSA (12.2.1.1) 554

Data Reduction (12.2.1.2) 554

Data Normalization (12.2.1.3) 556

Data Archiving (12.2.1.4) 557

Investigating Network Data (12.2.2) 558

Working in Sguil (12.2.2.1) 559

Sguil Queries (12.2.2.2) 560

Pivoting from Sguil (12.2.2.3) 562

Event Handling in Sguil (12.2.2.4) 563

Working in ELSA (12.2.2.5) 564

Queries in ELSA (12.2.2.6) 565

Investigating Process or API Calls (12.2.2.7) 567

Investigating File Details (12.2.2.8) 568

Enhancing the Work of the Cybersecurity Analyst (12.2.3) 569

Dashboards and Visualizations (12.2.3.1) 570

Workflow Management (12.2.3.2) 570

Digital Forensics (12.3) 570

Evidence Handling and Attack Attribution (12.3.1) 570

Digital Forensics (12.3.1.1) 571

The Digital Forensics Process (12.3.1.2) 572

Types of Evidence (12.3.1.3) 573

Evidence Collection Order (12.3.1.4) 573

Chain of Custody (12.3.1.5) 574
Data Integrity and Preservation (12.3.1.6) 574
Attack Attribution (12.3.1.7) 575

Summary (12.4) 577

Practice 578

Check Your Understanding 578

Chapter 13 Incident Response and Handling 581

Objectives 581

Key Terms 581

Introduction (13.0) 582

Incident Response Models (13.1) 582

The Cyber Kill Chain (13.1.1) 582
Steps of the Cyber Kill Chain (13.1.1.1) 582
Reconnaissance (13.1.1.2) 583
Weaponization (13.1.1.3) 584
Delivery (13.1.1.4) 585
Exploitation (13.1.1.5) 585
Installation (13.1.1.6) 586
Command and Control (13.1.1.7) 586
Actions on Objectives (13.1.1.8) 587
The Diamond Model of Intrusion (13.1.2) 588
Diamond Model Overview (13.1.2.1) 588
Pivoting Across the Diamond Model (13.1.2.2) 589
The Diamond Model and the Cyber Kill Chain (13.1.2.3) 590
The VERIS Schema (13.1.3) 591
What Is the VERIS Schema? (13.1.3.1) 592
Create a VERIS Record (13.1.3.2) 592
Top-Level and Second-Level Elements (13.1.3.3) 594
The VERIS Community Database (13.1.3.4) 598

Incident Handling (13.2) 599

CSIRTs (13.2.1) 599
CSIRT Overview (13.2.1.1) 599
Types of CSIRTs (13.2.1.2) 599
CERT (13.2.1.3) 600
NIST 800-61r2 (13.2.2) 601
Establishing an Incident Response Capability (13.2.2.1) 601
Incident Response Stakeholders (13.2.2.2) 602
NIST Incident Response Life Cycle (13.2.2.3) 603

<i>Preparation (13.2.2.4)</i>	604
<i>Detection and Analysis (13.2.2.5)</i>	605
<i>Containment, Eradication, and Recovery (13.2.2.6)</i>	607
<i>Post-Incident Activities (13.2.2.7)</i>	609
<i>Incident Data Collection and Retention (13.2.2.8)</i>	610
<i>Reporting Requirements and Information Sharing (13.2.2.9)</i>	612

Summary (13.3) 613

Practice 614

Check Your Understanding 614

Appendix A Answers to the “Check Your Understanding” Questions 619

Glossary 635

Index 655

Command Syntax Conventions

The conventions used to present command syntax in this book are the same conventions used in the IOS Command Reference. The Command Reference describes these conventions as follows:

- **Boldface** indicates commands and keywords that are entered literally as shown. In actual configuration examples and output (not general command syntax), boldface indicates commands that are manually input by the user (such as a **show** command).
- *Italic* indicates arguments for which you supply actual values.
- Vertical bars (|) separate alternative, mutually exclusive elements.
- Square brackets ([]) indicate an optional element.
- Braces ({ }) indicate a required choice.
- Braces within brackets ([{ }]) indicate a required choice within an optional element.

Introduction

CCNA Cybersecurity Operations Companion Guide is the official supplemental textbook for the Cisco Networking Academy CCNA Cybersecurity Operations v1.x course. Cisco Networking Academy is a comprehensive program that delivers information technology skills to students around the world. The curriculum emphasizes real-world practical application, while providing opportunities for you to gain the skills needed to successfully handle the tasks, duties, and responsibilities of an associate-level cybersecurity analyst working in a Security Operations Center (SOC).

As a textbook, this book provides a ready reference to explain the same concepts, technologies, protocols, and tools as the online curriculum. You can use the online curriculum as directed by your instructor and then use this *Companion Guide*'s study tools to help solidify your understanding of all the topics.

Who Should Read This Book

The book, as well as the course, is designed as an introduction to cybersecurity operations for those pursuing careers as a cybersecurity analyst. Topics are presented concisely, starting with the most fundamental concepts and progressing to a comprehensive understanding of security monitoring, intrusion analysis, and incident response. The content of this book provides preparation for the CCNA Cyber Ops certification exams (SECFND and SECOPS).

Book Features

The educational features of this book focus on supporting topic coverage, readability, and practice of the course material to facilitate your full understanding of the course material.

Topic Coverage

The following features give you a thorough overview of the topics covered in each chapter so that you can make constructive use of your study time:

- **Objectives:** Listed at the beginning of each chapter, the objectives reference the core concepts covered in the chapter. The objectives match the objectives stated in the corresponding chapters of the online curriculum; however, the question format in the *Companion Guide* encourages you to think about finding the answers as you read the chapter.

- **Notes:** These are short sidebars that point out interesting facts, time-saving methods, and important safety issues.
- **Chapter summaries:** At the end of each chapter is a summary of the chapter's key concepts. It provides a synopsis of the chapter and serves as a study aid.
- **Practice:** At the end of chapter there is a full list of all the labs, class activities, and Packet Tracer activities to refer back to for study time.

Readability

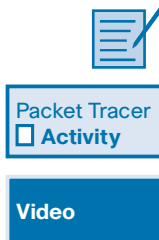
The following features assist your understanding of the networking vocabulary:

- **Key terms:** Each chapter begins with a list of key terms, along with a page number reference from inside the chapter. The terms are listed in the order in which they are explained in the chapter. This handy reference allows you to find a term, flip to the page where the term appears, and see the term used in context. The Glossary defines all the key terms.
- **Glossary:** This book contains an all new Glossary with almost 400 terms.

Practice

Practice makes perfect. This *Companion Guide* offers you ample opportunities to put what you learn into practice. You will find the following features valuable and effective in reinforcing the instruction that you receive:

- **Check Your Understanding questions and answer key:** Review questions are presented at the end of each chapter as a self-assessment tool. These questions match the style of questions that you see in the online course. Appendix A, “Answers to the ‘Check Your Understanding’ Questions,” provides an answer key to all the questions and includes an explanation of each answer.
- **Labs and activities:** Throughout each chapter, you will be directed back to the online course to take advantage of the activities created to reinforce concepts. In addition, at the end of each chapter, there is a practice section that collects a list of all the labs and activities to provide practice with the topics introduced in that chapter.
- **Page references to online course:** After headings, you will see, for example, (1.1.2.3). This number refers to the page number in the online course so that you can easily jump to that spot online to view a video, practice an activity, perform a lab, or review a topic.





About Packet Tracer Software and Activities

Interspersed throughout the chapters you'll find a few Cisco Packet Tracer activities. Packet Tracer allows you to create networks, visualize how packets flow in the network, and use basic testing tools to determine whether the network would work. When you see this icon, you can use Packet Tracer with the listed file to perform a task suggested in this book. The activity files are available in the course. Packet Tracer software is available only through the Cisco Networking Academy website. Ask your instructor for access to Packet Tracer.

How This Book Is Organized

This book corresponds closely to the Cisco Networking Academy CCNA Cybersecurity Operations v1 course and is divided into 13 chapters, one appendix, and a glossary of key terms:

- **Chapter 1, “Cybersecurity and the Security Operations Center”:** This chapter examines why networks and data are attacked and how to prepare for a career in cybersecurity operations.
- **Chapter 2, “Windows Operating System”:** This chapter discusses the features and characteristics of the Windows operating system, including its operation and how to secure Windows endpoints.
- **Chapter 3, “Linux Operating System”:** This chapter discusses the features and characteristics of the Linux operating system, including basic operation in the Linux shell, basic administrative tasks, and basic security-related tasks on a Linux host.
- **Chapter 4, “Network Protocols and Services”:** This chapter discusses the operation of network protocols and services, including network operations, Ethernet and IP, common testing utilities, address resolution, transport functionality, and applications that provide network services.
- **Chapter 5, “Network Infrastructure”:** This chapter discusses network infrastructure, including wired and wireless networks, network security devices, and network topologies.
- **Chapter 6, “Principles of Network Security”:** This chapter discusses the various types of network attacks, including how networks are attacked and the various types of threats and attacks.
- **Chapter 7, “Network Attacks: A Deeper Look”:** This chapter dives deeper into network attacks, including how to identify attacks using network monitoring tools. Also, the vulnerabilities of TCP/IP and network applications are discussed.

- **Chapter 8, “Protecting the Network”:** This chapter discusses methods to prevent malicious access to networks, hosts, and data, including approaches to network security defense, access control methods, and using various intelligence sources to locate current security threats.
- **Chapter 9, “Cryptography and the Public Key Infrastructure”:** This chapter discusses the impact of cryptography on network security monitoring, including tools to encrypt and decrypt data and the public key infrastructure (PKI).
- **Chapter 10, “Endpoint Security and Analysis”:** This chapter discusses how to investigate endpoint vulnerabilities and attacks, including malware analysis and endpoint vulnerability assessment.
- **Chapter 11, “Security Monitoring”:** This chapter discusses how to identify network security alerts, including how network security technologies affect security monitoring and the type of log files used in security monitoring.
- **Chapter 12, “Intrusion Data Analysis”:** This chapter discusses how to analyze network intrusion data to verify potential exploits, including the process of evaluating alerts, determining the source of an alert, and the handling of evidence to ensure proper attack attribution.
- **Chapter 13, “Incident Response and Handling”:** This chapter discusses how to apply incident response models to manage security incidents. Response models include the Cyber Kill Chain, the Diamond Model of intrusion, the VERIS schema, and NIST 800-61r2 standards.
- **Appendix A, “Answers to the ‘Check Your Understanding’ Questions”:** This appendix lists the answers to the “Check Your Understanding” review questions that are included at the end of each chapter.
- **Glossary:** The Glossary provides you with definitions for all the key terms identified in each chapter.

This page intentionally left blank

Cybersecurity and the Security Operations Center

Objectives

Upon completion of this chapter, you will be able to answer the following questions:

- What are some features of examples of cybersecurity incidents?
- What are the motivations of the threat actors behind specific security incidents?
- What is the potential impact of network security attacks?
- What is the mission of the Security Operations Center (SOC)?
- What are some resources available to prepare for a career in cybersecurity operations?

Key Terms

This chapter uses the following key terms. You can find the definitions in the Glossary.

threat actors page 2

ransomware page 3

malware page 3

hacktivists page 4

script kiddies page 4

distributed denial of service (DDoS) page 4

*personally identifiable
information (PII)* page 5

protected health information (PHI) page 6

Security Operations Center (SOC) page 7

Tier 1 Alert Analyst page 8

Tier 2 Incident Responder page 8

*Tier 3 Subject Matter Expert
(SME)/Hunter* page 8

SOC Manager page 8

*security information and event
management system (SIEM)* page 9

Introduction (1.0)

In this chapter, you will learn about the who, what, and why of cyberattacks. Different people commit cybercrime for different reasons. Security Operations Centers (SOC) work to combat cybercrime. People prepare for work in a SOC by earning certifications, seeking formal education, and by using employment services to gain internship experience and jobs.



Class Activity 1.0.1.2: Top Hacker Shows Us How It is Done

In this class activity, you will view a TED Talk video that discusses various security vulnerabilities. You will also research one of the vulnerabilities mentioned in the video.

The Danger (1.1)

In this section, you will learn some common war stories in the cybersecurity arena as well as some of the major *threat actors* and threat impacts.

War Stories (1.1.1)

In this topic, you will learn about three types of victims in cybercrime: individuals, organizations, and nations.

Hijacked People (1.1.1.1)

Sarah stopped by her favorite coffee shop to grab her afternoon drink. She placed her order, paid the clerk, and waited while the baristas worked furiously to fulfill the backup of orders. Sarah pulled out her phone, opened the wireless client, and connected to what she assumed was the coffee shop's free wireless network.

However, sitting in a corner of the store, a hacker had just set up an open “rogue” wireless hotspot posing as the coffee shop's wireless network. When Sarah logged onto her bank's website, the hacker hijacked her session, and gained access to her bank accounts.

View the following video posted in 2008 to see a demonstration of how one wireless network was vulnerable to hacking:

<https://www.youtube.com/watch?v=zcmMFQGxMNU>

In this course, you will learn about security technologies that easily prevent this type of attack.

Ransomed Companies (1.1.1.2)

Rashid, an employee in the finance department of a major, publicly held corporation, receives an email from his CEO with an attached PDF. The PDF is about the company's third-quarter earnings. Rashid does not remember his department creating the PDF. His curiosity is peaked, so he opens the attachment.

The same scenario plays out across the organization as dozens of other employees are successfully enticed to click the attachment. When the PDF opens, *ransomware* is installed on the employees' computers and begins the process of gathering and encrypting corporate data. The goal of the attackers is financial gain, because they hold the company's data for ransom until they are paid.

View the following video to see a dramatization of how this ransomware attack could happen:

<https://www.youtube.com/watch?v=4gR562GW7TITargeted>

Nations (1.1.1.3)

Some of today's *malware* is so sophisticated and expensive to create that security experts believe only a nation state or group of nations could possibly have the influence and funding to create it. Such malware can be targeted to attack a nation's vulnerable infrastructure, such as the water system or power grid.

This was the purpose of the Stuxnet worm, which infected USB drives. These drives were carried by five Iranian component vendors, with the intention of infiltrating nuclear facilities supported by the vendors. Stuxnet was designed to infiltrate Windows operating systems and then target Step 7 software. Step 7 was developed by Siemens for their programmable logic controllers (PLC). Stuxnet was looking for a specific model of the Siemens PLCs that controls the centrifuges in nuclear facilities. The worm was transmitted from the infected USB drives into the PLCs and eventually damaged many of these centrifuges.

Zero Days, a film released in 2016, attempts to document the development and deployment of the Stuxnet targeted malware attack. Search the Internet for a web location where you can view the film.



Lab 1.1.1.4: Installing the CyberOps Workstation Virtual Machine

In this lab, you will install VirtualBox on your personal computer. You will then download and install the CyberOps Workstation Virtual Machine (VM).



Lab 1.1.1.5: Cybersecurity Case Studies

In this lab, you will analyze the given cases and answer questions about them.

Threat Actors (1.1.2)

In this topic, you will learn about the motivations of the threat actors behind specific security incidents.

Amateurs (1.1.2.1)

Threat actors include, but are not limited to, amateurs, *hacktivists*, organized crime groups, state-sponsored and terrorist groups. Threat actors are individuals or a group of individuals who perform cyberattacks against another individual or organization. Cyberattacks are intentional, malicious acts meant to negatively impact another individual or organization.

Amateurs, also known as *script kiddies*, have little or no skill. They often use existing tools or instructions found on the Internet to launch attacks. Some are just curious, while others try to demonstrate their skills by causing harm. Even though they are using basic tools, the results can still be devastating.

Hacktivists (1.1.2.2)

Hacktivists are hackers who protest against a variety of political and social ideas. Hacktivists publicly protest against organizations or governments by posting articles and videos, leaking sensitive information, and disrupting web services with illegitimate traffic in *distributed denial of service (DDoS)* attacks.

Financial Gain (1.1.2.3)

Much of the hacking activity that consistently threatens our security is motivated by financial gain. These cybercriminals want to gain access to our bank accounts, personal data, and anything else they can leverage to generate cash flow.

Trade Secrets and Global Politics (1.1.2.4)

The past several years have seen many stories about nation states hacking other countries, or otherwise interfering with internal politics. Nation states are also interested in using cyberspace for industrial espionage. The theft of intellectual property can give a country a significant advantage in international trade.

Defending against the fallout from state-sponsored cyberespionage and cyberwarfare will continue to be a priority for cybersecurity professionals.

How Secure Is the Internet of Things? (1.1.2.5)

The Internet of Things (IoT) is all around us and quickly expanding. We are just beginning to reap the benefits of the IoT. New ways to use connected things are being developed daily. The IoT helps individuals connect things to improve their

quality of life. For example, many people are now using connected wearable devices to track their fitness activities. How many devices do you currently own that connect to your home network or the Internet?

How secure are these devices? For example, who wrote the firmware? Did the programmer pay attention to security flaws? Is your connected home thermostat vulnerable to attacks? What about your DVR? If security vulnerabilities are found, can firmware in the device be patched to eliminate the vulnerability? Many devices on the Internet are not updated with the latest firmware. Some older devices were not even developed to be updated with patches. These two situations create opportunity for threat actors and security risks for the owners of these devices.

In October 2016, a DDoS attack against the domain name provider Dyn took down many popular websites. The attack came from a large number of webcams, DVRs, routers, and other IoT devices that had been compromised by malicious software. These devices formed a “botnet” that was controlled by hackers. This botnet was used to create an enormous DDoS attack that disabled essential Internet services. Dyn has posted a blog [here](#) to explain the attack and their reaction to it.

Avi Rubin, Professor of Computer Science at Johns Hopkins University and Technical Director of the JHU Information Security Institute, highlights the dangers of not securing all our connected devices. Search the Internet to view his TED talk.



Lab 1.1.2.6: Learning the Details of Attacks

In this lab, you will research and analyze IoT application vulnerabilities.

Threat Impact (1.1.3)

In this topic, you will learn about the potential impact of network security attacks.

PII and PHI (1.1.3.1)

The economic impact of cyberattacks is difficult to ascertain with precision; however, according to an article in *Forbes*, it is estimated that businesses lose \$400 billion annually to cyberattacks.

Personally identifiable information (PII) is any information that can be used to positively identify an individual. Examples of PII include:

- Name
- Social security number
- Birthdate
- Credit card numbers

- Bank account numbers
- Government issued ID
- Address information (street, email, phone numbers)

One of the more lucrative goals of cybercriminals is obtaining lists of PII that can then be sold on the dark web. The dark web can only be accessed with special software and is used by cybercriminals to shield their activities. Stolen PII can be used to create fake accounts, such as credit cards and short-term loans.

A subset of PII is *protected health information (PHI)*. The medical community creates and maintains electronic medical records (EMR) that contain PHI. In the United States, handling of PHI is regulated by the Health Insurance Portability and Accountability Act (HIPAA). The equivalent regulation in the European Union is called Data Protection.

Most hacks on companies and organizations reported in the news involved stolen PII or PHI. In only three months in 2016, the following attacks occurred:

- In March 2016, a data breach at a health care provider exposed the personal information of 2.2 million patients.
- In April 2016, a laptop and portable drives were stolen from a government agency that included personal information for as many as 5 million people.
- In May 2016, a data breach at a payroll company exposed the payroll, tax, and benefits information of over 600,000 companies.

Lost Competitive Advantage (1.1.3.2)

Companies are increasingly worried about corporate espionage in cyberspace. An additional major concern is the loss of trust that comes when a company is unable to protect its customers' personal data. The loss of competitive advantage may come from this loss of trust rather than another company or country stealing trade secrets.

Politics and National Security (1.1.3.3)

It is not just businesses that get hacked. In February 2016, a hacker published the personal information of 20,000 U.S. Federal Bureau of Investigation (FBI) employees and 9,000 U.S. Department of Homeland Security (DHS) employees. The hacker was apparently politically motivated.

The Stuxnet worm was specifically designed to impede Iran's progress in enriching uranium that could be used in a nuclear weapon. Stuxnet is a prime example of a network attack motivated by national security concerns. Cyberwarfare is a serious possibility. State-supported hacker warriors can cause disruption and destruction of vital services and resources within an enemy nation. The Internet has become essential as a medium for commercial and financial activities. Disruption of these activities can devastate a nation's economy. Controllers, similar to those attacked by Stuxnet, also

are used to control the flow of water at dams and the switching of electricity on the power grid. Attacks on such controllers can have dire consequences.



Lab 1.1.3.4: Visualizing the Black Hats

In this lab, you will research and analyze cybersecurity incidents to create scenarios of how organizations can prevent or mitigate an attack.

Fighters in the War Against Cybercrime (1.2)

In this section, you will learn about the *Security Operations Center (SOC)* and how to become a defender in the cybersecurity arena.

The Modern Security Operations Center (1.2.1)

In this topic, you will learn about the people, processes, and technologies in an SOC.

Elements of an SOC (1.2.1.1)

Defending against today's threats requires a formalized, structured, and disciplined approach, which is executed by professionals at SOC's. SOC's provide a broad range of services, from monitoring and management, to comprehensive threat solutions and hosted security that can be customized to meet customer needs. SOC's can be wholly in-house, owned and operated by a business, or elements of an SOC can be contracted out to security vendors, such as Cisco's Managed Security Services.

The major elements of an SOC, shown in Figure 1-1, are people, processes, and technology.

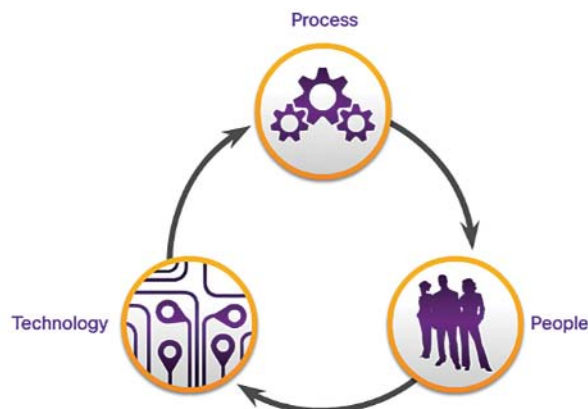


Figure 1-1 Elements of a Security Operations Center

People in the SOC (1.2.1.2)

The SANS Institute (<https://www.sans.org>) classifies the roles people play in a SOC into four job titles:

- **Tier 1 Alert Analyst:** These professionals monitor incoming alerts, verify that a true incident has occurred, and forward tickets to Tier 2, if necessary.
- **Tier 2 Incident Responder:** These professionals are responsible for deep investigation of incidents and advise remediation or action to be taken.
- **Tier 3 Subject Matter Expert (SME)/Hunter:** These professionals have expert-level skill in network, endpoint, threat intelligence, and malware reverse engineering. They are experts at tracing the processes of the malware to determine its impact and how it can be removed. They are also deeply involved in hunting for potential threats and implementing threat detection tools.
- **SOC Manager:** This professional manages all the resources of the SOC and serves as the point of contact for the larger organization or customer.

This course offers preparation for a certification suitable for the position of Tier 1 Alert Analyst, also known as Cybersecurity Analyst.

Figure 1-2 graphically represents how these roles interact with each other.

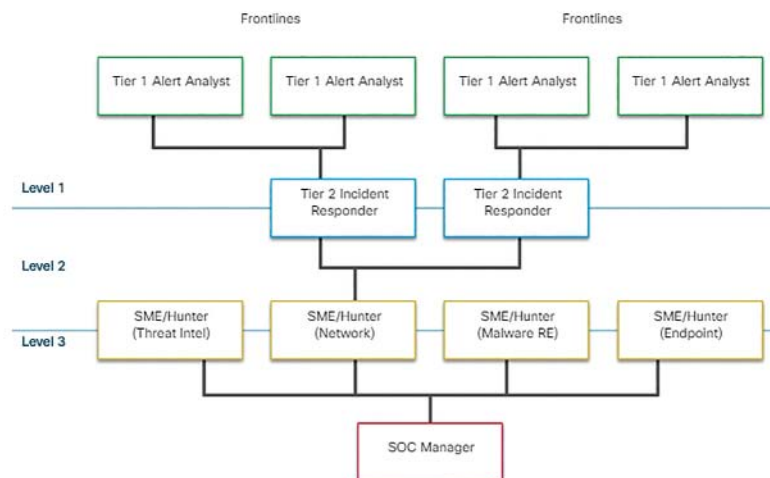


Figure 1-2 Roles of the People in a Security Operations Center

Process in the SOC (1.2.1.3)

The day of a Tier 1 Analyst begins with monitoring security alert queues. A ticketing system is frequently used to allow analysts to select alerts from a queue to investigate. Because the software that generates alerts can trigger false alarms, one job of

the Tier 1 Analyst might be to verify that an alert represents a true security incident. When verification is established, the incident can be forwarded to investigators or other security personnel to be acted upon, or resolved as a false alarm.

If a ticket cannot be resolved, the Tier 1 Analyst will forward the ticket to a Tier 2 Analyst for deeper investigation and remediation. If the Tier 2 Analyst cannot resolve the ticket, she will forward it to a Tier 3 Analyst with in-depth knowledge and threat hunting skills.

Figure 1-3 summarizes the roles of Tier 1, Tier 2, and Tier 3 analysts.



Figure 1-3 Threat Incident Escalation Process

Technologies in the SOC (1.2.1.4)

As shown in Figure 1-4, a SOC needs a *security information and event management system (SIEM)*, or its equivalent. This system combines data from multiple technologies. SIEM systems are used for collecting and filtering data, detecting and classifying threats, analyzing and investigating threats, and managing resources to implement preventive measures and address future threats. SOC technologies include one or more of the following:

- Event collection, correlation, and analysis
- Security monitoring
- Security control
- Log management
- Vulnerability assessment
- Vulnerability tracking
- Threat intelligence

Figure 1-4 is a simplified representation of an SOC monitoring system. Information about network traffic, network flows, system logs, endpoint data, intelligence threat feeds, security events, and identifying asset context are all fed into the SIEM system.

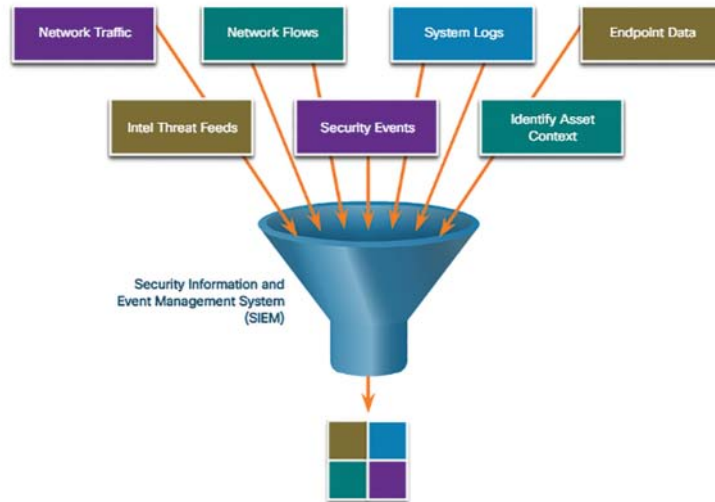


Figure 1-4 SOC Monitoring System

Enterprise and Managed Security (1.2.1.5)

For medium and large networks, the organization will benefit from implementing an enterprise-level SOC. The SOC can be a complete in-house solution. However, many larger organizations will outsource at least part of the SOC operations to a security solutions provider.

Cisco has a team of experts who help ensure timely and accurate incident resolution. Cisco offers a wide range of incident response, preparedness, and management capabilities:

- Cisco Smart Net Total Care Service
- Cisco Product Security Incident Response Team (PSIRT)
- Cisco Computer Security Incident Response Team (CSIRT)
- Cisco Managed Services
- Cisco Tactical Operations (TacOps)
- Cisco's Safety and Physical Security Program

Security vs. Availability (1.2.1.6)

Most enterprise networks must be up and running at all times. Security personnel understand that for the organization to accomplish its priorities, network availability must be preserved.

Each business or industry has a limited tolerance for network downtime. That tolerance is usually based upon a comparison of the cost of the downtime in relation to the cost of ensuring against downtime. For example, in a small retail business with only one location, it may be tolerable to have a router as a single point of failure. However, if a large portion of that business’s sales are from online shoppers, then the owner may decide to provide a level of redundancy to ensure that a connection is always available.

Preferred uptime is often measured in the number of down minutes in a year, as shown in Table 1-1. For example, a “five nines” uptime means that the network is up 99.999% of the time or down for no more than 5 minutes a year. “Four nines” would be a downtime of 53 minutes a year.

Table 1-1 Availability and Downtime

Availability %	Downtime
99.8%	17.52 hours
99.9% (“three nines”)	8.76 hours
99.99% (“four nines”)	52.56 minutes
99.999% (“five nines”)	5.256 minutes
99.9999% (“six nines”)	31.5 seconds
99.99999% (“seven nines”)	3.15 seconds

However, security cannot be so strong that it interferes with the needs of employees or business functions. It is always a tradeoff between strong security and permitting efficient business functioning.

Interactive
Graphic

Activity 1.2.1.7: Identify the SOC Terminology

Refer to the online course to complete this Activity.

Becoming a Defender (1.2.2)

In this topic, you will learn about the available certifications, degrees, and opportunities for gaining experience in cybersecurity operations.

Certifications (1.2.2.1)

A variety of cybersecurity certifications that are relevant to careers in SOCs are available from several different organizations.

Cisco CCNA Cyber Ops

The CCNA Cyber Ops certification provides a valuable first step in acquiring the knowledge and skills needed to work with a SOC team. It can be a valuable part of a career in the exciting and growing field of cybersecurity operations.

CompTIA Cybersecurity Analyst Certification

The CompTIA Cybersecurity Analyst (CSA+) certification is a vendor-neutral IT professional certification. It validates knowledge and skills required to configure and use threat detection tools, perform data analysis, and interpret the results to identify vulnerabilities, threats, and risks to an organization. The end goal is the ability to secure and protect applications and systems within an organization.

(ISC)² Information Security Certifications

(ISC)² is an international non-profit organization that offers the highly acclaimed CISSP certification. (ISC)² offers a range of other certifications for various specialties in cybersecurity.

Global Information Assurance Certification (GIAC)

GIAC, which was founded in 1999, is one of the oldest security certification organizations. It offers a wide range of certifications in seven categories.

Other Security-Related Certifications

Search for “cybersecurity certifications” to find information about other vendor and vendor-neutral certifications.

Further Education (1.2.2.2)

Degrees

Anyone considering a career in the cybersecurity field, should seriously consider pursuing a technical degree or bachelor’s degree in computer science, electrical engineering, information technology, or information security. Many educational institutions offer security-related specialized tracks and certifications.

Python Programming

Computer programming is an essential skill for anyone who wishes to pursue a career in cybersecurity. If you have never learned how to program, then Python might be the first language to learn. Python is an open-source, object-oriented language that is routinely used by cybersecurity analysts. It is also a popular programming language for Linux-based systems and software-defined networking (SDN).

Sources of Career Information (1.2.2.3)

A variety of websites and mobile applications advertise information technology jobs. Each site targets a variety of job applicants and provides different tools for candidates to research their ideal job position. Many sites are job site aggregators. Job site aggregators gather listings from other job boards and company career sites and display them in a single location.

Indeed.com

Advertised as the world's #1 job site, Indeed.com attracts over 180 million unique visitors every month from over 50 different countries. Indeed.com is truly a world-wide job site. It helps companies of all sizes hire the best talent and offers the best opportunity for job seekers.

CareerBuilder.com

CareerBuilder serves many large and prestigious companies. As a result, this site attracts specific candidates that typically have more education and higher credentials. The employers posting on CareerBuilder commonly get more candidates with college degrees, advanced credentials, and industry certifications.

USAJobs.gov

The United States federal government posts any openings on USAJobs:

<https://www.usajobs.gov>

Salary Information

The website [glassdoor.com](https://www.glassdoor.com) provides salary information for different job types, companies, and locations. Search for “cyber security analyst” to see salaries and requirements for current job openings.

Getting Experience (1.2.2.4)

There are variety of ways to get experience. The following are a few ideas.

Internships

Internships are an excellent method for gaining entry into the cybersecurity field. Sometimes, internships turn into an offer of full-time employment. However, even a temporary internship allows you the opportunity to gain experience in the inner workings of a cybersecurity organization. The contacts you make during an internship can also prove to be a valuable resource as you continue your career.

Search the Internet for a *Forbes* article titled “The 10 Best Websites For Finding An Internship.”

Cisco Cybersecurity Scholarship

To help close the security skills gap, Cisco introduced the Global Cybersecurity Scholarship program in 2016. Cisco is motivated to increase the pool of talent with critical cybersecurity proficiency. Registration opens in spring and awards are announced in late fall. Visit the following website to learn more about the scholarship:

<https://mkto.cisco.com/Security-Scholarship>

Temporary Agencies

If you are having difficulty finding your first job, a temporary agency can be a great place to start. Most temporary agencies will help you polish your resume and make recommendations on additional skills you may need to obtain to make yourself more attractive to potential employers.

Many organizations use temporary agencies to fill job openings for the first 90 days. Then, if the employee is a good match, the organization may offer to buy the contract from the temporary agency, converting the employee to a full-time, permanent position.

Your First Job

If you have no experience in the cybersecurity field, then you will most likely look for a company that is willing to train you for a position similar to a Tier 1 Analyst. Working for a call center or support desk may be your first step into gaining the experience you need to move ahead in your career.

How long should you stay in your first job? Generally, you want to make it through a full review cycle before leaving a company. That is, you typically want to make it past 18 months. Potential employers will normally want to know if you met or exceeded expectations in your current or past jobs.



Lab 1.2.2.5: Becoming a Defender

In this lab, you will research and analyze what it takes to become a network defender.

Summary (1.3)

In the beginning of the chapter you learned that people, companies, and even nations can all fall victim to cyberattacks. There are various types of attackers, including amateurs who attack for fun and prestige, hacktivists who hack to further a political cause, and professional hackers who attack for profit. In addition, nations may attack other nations to gain economic advantage through the theft of intellectual property, or to damage or destroy the assets of another country. The networks that are vulnerable to attack are not just business networks of PCs and servers, but also the thousands of devices on the Internet of Things.

SOCs are responsible for preventing, detecting, and responding to cybercrime. SOC consist of people following processes to use technologies to respond to threats. There are four main roles in the SOC. Tier 1 Analysts verify security alerts using network data. Tier 2 Incident Responders investigate verified incidents and decide on how to act. Tier 3 SMEs/Hunters are experts and are able to investigate threats at the highest level. The fourth role is the SOC Managers. They manage the resources of the center and communicate with customers. Customers can be internal or external. A SOC may be operated by a single company or may provide services to many companies. Finally, although network security is extremely important, it cannot interfere with the ability of the company and its employees to fulfill the mission of an organization.

In order to work in an SOC, you learned that you can study to earn certifications that are offered by a number of different organizations. In addition, you can pursue degrees in higher education that are relevant to cyberoperations, and learn other skills such as programming in Python. Job leads can be found at a number of employment websites, and agencies can help you to find temporary jobs, internships, or permanent employment.

Practice

The following activities provide practice with the topics introduced in this chapter. The Labs and Class Activities are available in the companion *CCNA Cybersecurity Operations Lab Manual* (ISBN 9781587134388).



Class Activities

Class Activity 1.0.1.2: Top Hacker Shows Us How It is Done

**Labs**

Lab 1.1.1.4: Installing the CyberOps Workstation Virtual Machine

Lab 1.1.1.5: Cybersecurity Case Studies

Lab 1.1.2.6: Learning the Details of Attacks

Lab 1.1.3.4: Visualizing the Black Hats

Lab 1.2.2.5: Becoming a Defender

Check Your Understanding

Complete all the review questions listed here to test your understanding of the topics and concepts in this chapter. The appendix “Answers to the ‘Check Your Understanding’ Questions” lists the answers.

1. A computer is presenting a user with a screen requesting payment before the user data is allowed to be accessed by the same user. What type of malware is this?
 - A. A type of virus
 - B. A type of logic bomb
 - C. A type of ransomware
 - D. A type of worm
2. What is cyberwarfare?
 - A. It is an attack only on military targets.
 - B. It is an attack on a major corporation.
 - C. It is an attack that only involves robots and bots.
 - D. It is an attack designed to disrupt, corrupt, or exploit national interests.
3. How can a security information and event management system in an SOC be used to help personnel fight against security threats?
 - A. By collecting and filtering data
 - B. By filtering network traffic
 - C. By authenticating users to network resources
 - D. By encrypting communications to remote sites
4. Which three technologies should be included in an SOC security information and event management system? (Choose three.)
 - A. Proxy service
 - B. User authentication

- C. Threat intelligence
 - D. Security monitoring
 - E. Intrusion prevention
 - F. Event collection, correlation, and analysis
5. What name is given to hackers who hack for a political or social cause?
- A. White hat
 - B. Hacker
 - C. Hacktivist
 - D. Blue hat
6. Which organization is an international nonprofit organization that offers the CISSP certification?
- A. (ISC)²
 - B. IEEE
 - C. GIAC
 - D. CompTIA
7. After a security incident is verified in a SOC, an incident responder reviews the incident but cannot identify the source of the incident and form an effective mitigation procedure. To whom should the incident ticket be escalated?
- A. A cyberoperations analyst for help
 - B. An SME for further investigation
 - C. An alert analyst for further analysis
 - D. The SOC manager to ask for other personnel to be assigned
8. The term Alert Analyst refers to which group of personnel in an SOC?
- A. Tier 1 personnel
 - B. Tier 2 personnel
 - C. Tier 3 personnel
 - D. SOC managers
9. What is a rogue wireless hotspot?
- A. It is a hotspot that was set up with outdated devices.
 - B. It is a hotspot that does not encrypt network user traffic.
 - C. It is a hotspot that does not implement strong user authentication mechanisms.
 - D. It is a hotspot that appears to be from a legitimate business but was actually set up by someone without the permission from the business.

This page intentionally left blank

Windows Operating System

Objectives

Upon completion of this chapter, you will be able to answer the following questions:

- What is the history of the Windows operating system?
- What is the architecture of Windows and its operation?
- How do you configure and monitor Windows?
- How is Windows kept secure?

Key Terms

This chapter uses the following key terms. You can find the definitions in the Glossary.

Disk Operating System (DOS) page 21

MS-DOS page 21

vulnerability page 26

Windows Defender page 26

encryption page 26

firewall page 26

hardware abstraction layer (HAL) page 27

kernel page 27

File Allocation Table (FAT) page 28

Extended FAT (exFAT) page 29

Hierarchical File System Plus (HFS+) page 29

Extended File System (EXT) page 29

New Technology File System (NTFS) page 29

Alternate Data Streams (ADSs) page 29

Partition Boot Sector page 31

Master File Table (MFT) page 31

System Files page 31

Basic Input-Output System (BIOS) page 31

Unified Extensible Firmware Interface (UEFI) page 31

master boot record (MBR) page 32

Boot Configuration Database (BCD) page 32

Kernel Mode Code Signing (KMCS) page 33

Session Manager Subsystem (SMSS) page 33

processes page 36

thread page 37

services page 37

registry page 38

domain page 44

domain controllers (DCs) page 44

command line interface (CLI) page 44

PowerShell page 44

*Windows Management Instrumentation
(WMI)* page 46

Task Manager page 49

Resource Monitor page 50

Server Message Block (SMB) page 56

netstat page 58

Event Viewer page 59

Introduction (2.0)

From its humble beginnings over 30 years ago in 1985, the Windows operating system has seen many iterations; from Windows 1.0 to today's current desktop version, Windows 10, and server version, Windows Server 2016.

This chapter covers some of the basic concepts of Windows, including how the operating system works and the tools used to secure Windows endpoints.



Class Activity 2.0.1.2: Identify Running Processes

In this lab, you will use TCP/UDP Endpoint Viewer, a tool in Sysinternals Suite, to identify any running processes on your computer.

Windows Overview (2.1)

In this section, you will learn about Window's history, architecture, and operations.

Windows History (2.1.1)

In this topic, you will learn about the beginnings of Windows, the history of Windows versions, the Windows graphical user interface (GUI), and Windows vulnerabilities.

Disk Operating System (2.1.1.1)

The first computers did not have modern storage devices such as hard drives, optical drives, or flash storage. The first storage methods used punch cards, paper tape, magnetic tape, and even audio cassettes.

Floppy disk and hard disk storage requires software to read from, write to, and manage the data that they store. A *Disk Operating System (DOS)* is an operating system that the computer uses to enable these data storage devices to read and write files. The DOS provides a file system which organizes the files in a specific way on the disk. *MS-DOS* is a DOS created by Microsoft. MS-DOS used a command line as the interface for people to create programs and manipulate data files, as shown in Figure 2-1.

```
Starting MS-DOS...

HIMEM is testing extended memory...done.

C:\>C:\DOS\SMARTDRV.EXE /X
C:\>dir

Volume in drive C is MS-DOS_6
Volume Serial Number is 4AA6-6939
Directory of C:\

DOS             <DIR>             05-06-17   1:09p
COMMAND.COM     54,645 05-31-94   6:22a
WINA20  386     9,349 05-31-94   6:22a
CONFIG.SYS      71 05-06-17   1:10p
AUTOEXEC.BAT    78 05-06-17   1:10p
               5 file(s)         64,143 bytes
               517,021,696 bytes free

C:\>_
```

Figure 2-1 MS-DOS 6.3

With MS-DOS, the computer had a basic working knowledge of how to access the disk drive and load the operating system files directly from the disk as part of the boot process. When it was loaded, MS-DOS could easily access DOS because it was built into the operating system.

Early versions of Windows consisted of a GUI that ran over MS-DOS, with the first being Windows 1.0 in 1985. The disk operating system still controlled the computer and its hardware. A modern operating system like Windows 10 is not considered a disk operating system. It is built on Windows NT, which stands for “New Technology.” The operating system itself is in direct control of the computer and its hardware. NT is an OS with support for multiple user processes. This is much different than the single-process, single-user MS-DOS.

Today, anything that used to be accomplished through the command line interface of MS-DOS can be accomplished in the Windows GUI. You can still experience what it was like to use MS-DOS by opening a command window, but what you see is no longer MS-DOS, it is a function of Windows. To experience a little of what it was like to work in MS-DOS, open a command window by typing **cmd** in Windows Search and pressing **Enter**. These are some commands that you can use:

- **dir**: Shows a listing of all the files in the current directory (folder)
- **cd *directory***: Changes the directory to the indicated directory
- **cd..**: Changes the directory to the directory above the current directory
- **cd**: Changes the directory to the root directory (often C:)
- **copy**: Copies files to another location

- **del:** Deletes one or more files
- **find:** Searches for text in files
- **mkdir:** Creates a new directory
- **ren:** Renames a file
- **help:** Displays all the commands that can be used, with a brief description
- **help *command*:** Displays extensive help for the indicated command

Windows Versions (2.1.1.2)

Since 1993, there have been more than 20 releases of Windows that are based on the NT operating system. Most of these versions were for use by the general public and businesses because of the file security offered by the file system that was used by the NT OS. Businesses also adopted NT OS-based Windows operating systems. This is because many editions were built specifically for the workstation, professional, server, advanced server, and datacenter server, to name just a few of the many purpose-built versions.

Beginning with Windows XP, a 64-bit edition was available. The 64-bit operating system was an entirely new architecture. It had a 64-bit address space instead of a 32-bit address space. This is not simply twice the amount of space because these bits are binary numbers. While 32-bit Windows can address a little less than 4 GB of RAM, 64-bit Windows can theoretically address 16.8 million terabytes. When the OS and the hardware all support 64-bit operation, extremely large data sets can be used. These large data sets include very large databases, scientific computing, and manipulation of high-definition digital video with special effects. In general, 64-bit computers and operating systems are backward-compatible with older, 32-bit programs, but 64-bit programs cannot be run on older, 32-bit hardware.

With each subsequent release of Windows, the operating system has become more refined by incorporating more features. Windows 7 was offered with six different editions, Windows 8 was offered with as many as four different editions, and Windows 10 is offered with eight different editions! Each edition not only offers different capabilities, but also different price points. Microsoft has said that Windows 10 is the last version of Windows, that Windows has become a service rather than just an OS. They say that rather than purchasing new operating systems, users will just update Windows 10 instead.

Table 2-1 lists the popular modern versions of Windows.

Table 2-1 Modern Windows Versions

OS Version	Editions
Windows 7	Starter, Home Basic, Home Premium, Professional, Enterprise, Ultimate
Windows Server 2008 R2	Foundation, Standard, Enterprise, Datacenter, Web Server, HPC Server, Itanium-Based Systems
Windows Home Server 2011	None
Windows 8	Windows 8, Windows 8 Pro, Windows 8 Enterprise, Windows RT
Windows Server 2012	Foundation, Essentials, Standard, Datacenter
Windows 8.1	Windows 8.1, Windows 8.1 Pro, Windows 8.1 Enterprise, Windows RT 8.1
Windows Server 2012 R2	Foundation, Essentials, Standard, Datacenter
Windows 10	Home, Pro, Pro Education, Enterprise, Education, IoT Core, Mobile, Mobile Enterprise
Windows Server 2016	Essentials, Standard, Datacenter, Multipoint Premium Server, Storage Server, Hyper-V Server

Windows GUI (2.1.1.3)

Windows has a graphical user interface (GUI) for users to work with data files and software. The GUI has a main area that is known as the Desktop, shown in Figure 2-2. The Desktop can be customized with various colors and background images. Windows supports multiple users, so each user can customize the Desktop to their liking. The Desktop can store files, folders, shortcuts to locations and programs, and applications. The Desktop also has a recycle bin icon, where files are stored when the user deletes them. Files can be restored from the recycle bin or the recycle bin can be emptied of files, which truly deletes them.

At the bottom of the desktop is the Task Bar. The Task Bar has three areas that are used for different purposes. At the left is the Start menu. It is used to access all of the installed programs, configuration options, and the search feature. At the center of the Task Bar, users place quick launch icons that run specific programs or open specific folders when they are clicked. Finally, on the right of the Task Bar is the notification area. The notification area shows, at a glance, the functionality of many different programs and features. For example, a blinking envelope icon may indicate new email, or a network icon with a red “x” may indicate a problem with the network.



Figure 2-2 Windows 10 GUI

Often, right-clicking an icon will bring up additional functions that can be used. This list is known as a Context Menu, shown in Figure 2-3. There are Context Menus for the icons in the notification area, and also for quick launch icons, system configuration icons, and for files and folders. The Context Menu provides many of the most commonly used functions by just clicking. For example, the Context Menu for a file will contain such items as Copy, Delete, Share, and Print. To open folders and manipulate files, Windows uses Windows File Explorer, also shown in Figure 2-3.

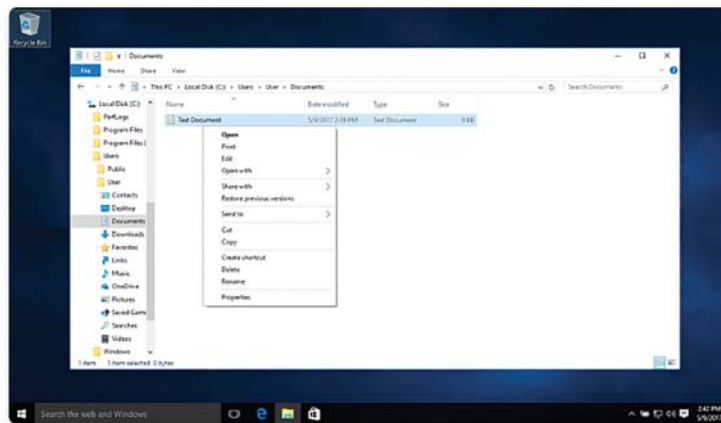


Figure 2-3 Windows File Explorer

Windows File Explorer is a tool used to navigate the entire file system of a computer, including multiple storage devices and network locations. Using Windows

File Explorer, you can easily create folders, copy files and folders, and move them around to different locations and devices. Basically, the tool has two main windows. The one on the left allows quick navigation to storage devices, parent folders, and child folders. The one on the right shows the content of the location that is selected in the left pane.

Operating System Vulnerabilities (2.1.1.4)

Operating systems consist of millions of lines of code. Installed software can also contain millions of lines of code. With all this code comes vulnerabilities. A *vulnerability* is some flaw or weakness that can be exploited by an attacker to reduce the viability of a computer's information. To take advantage of an operating system vulnerability, the attacker must use a technique or a tool to exploit the vulnerability. The attacker can then use the vulnerability to get the computer to act in a fashion outside of its intended design. In general, the goal is to gain unauthorized control of the computer, change permissions, or manipulate data.

These are some common Windows OS security recommendations:

- **Virus or malware protection:** By default, Windows uses *Windows Defender*. Windows Defender provides a suite of protection tools built into the system. If Windows Defender is turned off, the system becomes more vulnerable to attacks and malware.
- **Unknown or unmanaged services:** There are many services that run behind the scenes. It is important to make sure that each service is identifiable and safe. With an unknown service running in the background, the computer can be vulnerable to attack.
- **Encryption:** When data is not encrypted, it can easily be gathered and exploited. This is important not only for desktop computers, but especially mobile devices.
- **Security policy:** A good security policy must be configured and followed. Many settings in the Windows Security Policy control can prevent attacks.
- **Firewall:** By default, Windows uses Windows Firewall to limit communication with devices on the network. Over time, rules may no longer apply. For example, a port may be left open that should no longer be readily available. It is important to review firewall settings periodically to ensure that the rules are still applicable and remove any that no longer apply.
- **File and share permissions:** These permissions must be set correctly. It is easy to just give the "Everyone" group Full Control, but this allows all people to do what they want to all files. It is best to provide each user or group with the minimum necessary permissions for all files and folders.

- **Weak or no password:** Many people choose weak passwords or do not use a password at all. It is especially important to make sure that all accounts, especially the Administrator account, have a very strong password.
- **Login as Administrator:** When a user logs in as an administrator, any program that they run will have the privileges of that account. It is best to log in as a Standard User and only use the Administrator password to accomplish certain tasks.

Windows Architecture and Operations (2.1.2)

In this topic, you will learn about the Windows hardware abstraction layer, user mode, kernel mode, file system, boot process, startup, shutdown, processes, threads, services, memory allocation, handles, and registry.

Hardware Abstraction Layer (2.1.2.1)

Windows computers use many different types of hardware. The operating system can be installed on a computer off of the shelf, or a computer built from the ground up. When the operating system is installed, it must be isolated from differences in hardware. The basic Windows architecture is shown in Figure 2-4. A *hardware abstraction layer (HAL)* is code that handles all of the communication between the hardware and the *kernel*. The kernel is the core of the operating system and has control over the entire computer. It handles all of the input and output requests, memory, and all of the peripherals connected to the computer.

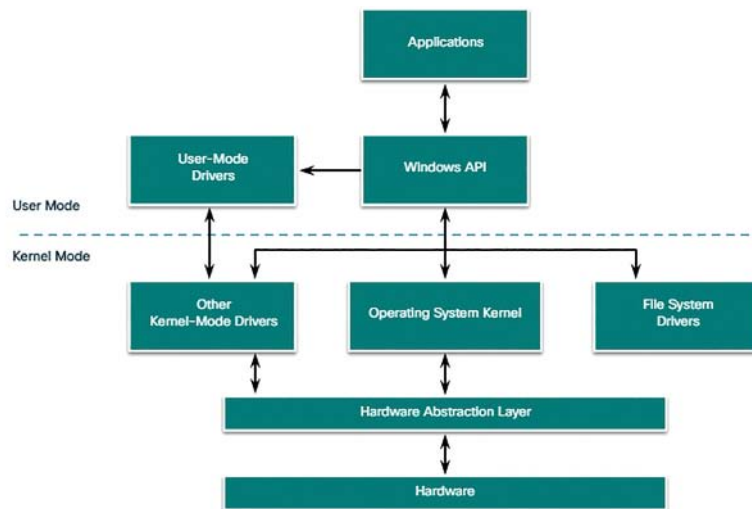


Figure 2-4 Basic Windows Architecture

In some instances, the kernel still communicates with the hardware directly, so it is not completely independent of the HAL. The HAL also needs the kernel to perform some functions.

User Mode and Kernel Mode (2.1.2.2)

There are two different modes in which a CPU operates when the computer has Windows installed: user mode and kernel mode. Installed applications run in user mode, and operating system code runs in kernel mode. Code that is executing in kernel mode has unrestricted access to the underlying hardware and is capable of executing any CPU instruction. Kernel mode code also can reference any memory address directly. Generally reserved for the most trusted functions of the OS, crashes in code running in kernel mode stop the operation of the entire computer. Conversely, programs such as user applications run in user mode and have no direct access to hardware or memory locations. User mode code must go through the operating system to access hardware resources. Because of the isolation provided by user mode, crashes in user mode are restricted to the application only and are recoverable. Most of the programs in Windows run in user mode. Device drivers, pieces of software that allow the operating system and a device to communicate, may run in either kernel or user mode, depending on the driver.

All of the code that runs in kernel mode uses the same address space. Kernel-mode drivers have no isolation from the operating system. If an error occurs with the driver running in kernel mode, and it writes to the wrong address space, the operating system or another kernel-mode driver could be adversely affected. In this respect, the driver might crash, causing the entire operating system to crash.

When user mode code runs, it is granted its own restricted address space by the kernel, along with a process created specifically for the application. The reason for this functionality is mainly to prevent applications from changing operating system code that is running at the same time. By having its own process, that application has its own private address space, rendering other applications unable to modify the data in it. This also helps to prevent the operating system and other applications from crashing if that application crashes.

Windows File Systems (2.1.2.3)

A file system is how information is organized on storage media. Some file systems may be a better choice to use than others, depending on the type of media that will be used. These are the file systems that Windows supports:

- **File Allocation Table (FAT):** This is a simple file system supported by many different operating systems. FAT has limitations to the number of partitions, partition sizes, and file sizes that it can address, so it is not usually used for hard drives (HDs) or solid state drives (SSDs) anymore. Both FAT16 and FAT32 are

available to use, with FAT32 being the most common because it has many fewer restrictions than FAT16.

- **Extended FAT (exFAT):** This is an extended version of FAT that has even fewer restrictions than FAT32, but is not supported very well outside of the Windows ecosystem.
- **Hierarchical File System Plus (HFS+):** This file system is used on macOS X computers and allows much longer filenames, file sizes, and partition sizes than previous file systems. Although it is not supported by Windows without special software, Windows is able to read data from HFS+ partitions.
- **Extended File System (EXT):** This file system is used with Linux-based computers. Although it is not supported by Windows, Windows is able to read data from EXT partitions with special software.
- **New Technology File System (NTFS):** This is the most commonly used file system when installing Windows. All versions of Windows and Linux support NTFS, while macOS X computers can only read an NTFS partition (they can write to an NTFS partition after installing special drivers).

NTFS is the most widely used file system for Windows for many reasons. NTFS supports very large files and partitions; it is very compatible with other operating systems. NTFS is also very reliable and supports recovery features. Most importantly, it supports many security features. Data access control is achieved through security descriptors. These security descriptors contain file ownership and permissions all the way down to the file level. NTFS also tracks many timestamps to track file activity. Sometimes referred to as MACE, the timestamps Modify, Access, Create, and Entry Modified are often used in forensic investigations to determine the history of a file or folder. NTFS also supports file system encryption to secure the entire storage media.

Alternate Data Streams

NTFS stores files as a series of attributes, such as the name of the file, or a timestamp. The data which the file contains is stored in the attribute \$DATA, and is known as a data stream. By using NTFS, you can connect **Alternate Data Streams (ADSs)** to the file. This is sometimes used by applications that are storing additional information about the file. The ADS is an important factor when discussing malware. This is because it is easy to hide data in an ADS. An attacker could store malicious code within an ADS that can then be called from a different file.

In the NTFS file system, a file with an ADS is identified after the filename and a colon, for example, Testfile.txt:ADSdata. This filename indicates an ADS called ADSdata is associated with the file called Testfile.txt. An example of ADS is shown in Example 2-1.

Example 2-1 Alternate Data Stream

```

C:\ADS> echo "Alternative Data Here" > Testfile.txt:ADS

C:\ADS> dir
Volume in drive C is OS
Volume Serial Number is F244-E247

Directory of C:\ADS

12/27/2017  03:03 PM    <DIR>          .
12/27/2017  03:03 PM    <DIR>          ..
12/27/2017  03:03 PM                0 Textfile.txt
               1 File(s)                0 bytes
               2 Dir(s)  402,725,310,464 bytes free

C:\ADS> more < Testfile.txt:ADS
"Alternative Data Here"

C:\ADS> dir /r
Volume in drive C has no label.
Volume Serial Number is F244-E247
Directory of C:\ADS

12/27/2017  03:03 PM    <DIR>          .
12/27/2017  03:03 PM    <DIR>          ..
12/27/2017  03:03 PM                0 Textfile.txt
                               24 Textfile.txt:ADS:$DATA
               1 File(s)                0 bytes
               2 Dir(s)  402,725,310,464 bytes free

C:\ADS>

```

- The first command places the text “Alternate Data Here” into an ADS of the file Testfile.txt called “ADS”.
- The next command, **dir**, shows that the file was created, but the ADS is not visible.
- The next command shows that there is data in the Testfile.txt:ADS data stream.
- The last command shows the ADS of the Testfile.txt file because the **r** switch was used with the **dir** command.

Before a storage device such as a disk can be used, it must be formatted with a file system. In turn, before a file system can be put into place on a storage device, the

device needs to be partitioned. A hard drive is divided into areas called partitions. Each partition is a logical storage unit that can be formatted to store information, such as data files or applications. During the installation process, most operating systems automatically partition and format the available drive space with a file system such as NTFS.

NTFS formatting creates important structures on the disk for file storage, and tables for recording the locations of files:

- **Partition Boot Sector:** This is the first 16 sectors of the drive. It contains the location of the Master File Table. The last 16 sectors contain a copy of the boot sector.
- **Master File Table (MFT):** This table contains the locations of all the files and directories on the partition, including file attributes such as security information and timestamps.
- **System Files:** These are hidden files that store information about other volumes and file attributes.
- **File Area:** The main area of the partition where files and directories are stored.

Note

When formatting a partition, the previous data may still be recoverable because not all the data is completely removed. The free space can be examined and files can be retrieved, which can compromise security. It is recommended to perform a secure wipe on a drive that is being reused. The secure wipe will write data to the entire drive multiple times to ensure there is no remaining data.

Windows Boot Process (2.1.2.4)

Many actions occur between the time when the computer power button is pressed and Windows is fully loaded, as shown in Figure 2-5.

Two types of computer firmware exist: *Basic Input-Output System (BIOS)* and *Unified Extensible Firmware Interface (UEFI)*. BIOS firmware was created in the early 1980s and works in the same way it did when it was created. As computers evolved, it became difficult for BIOS firmware to support all the new features requested by users. UEFI was designed to replace BIOS and support the new features.

In BIOS firmware, the process begins with the BIOS initialization phase. This is when hardware devices are initialized and a power-on self-test (POST) is performed to make sure all of these devices are communicating. When the system disk is

discovered, the POST ends. The last instruction in the POST is to look for the *master boot record (MBR)*.

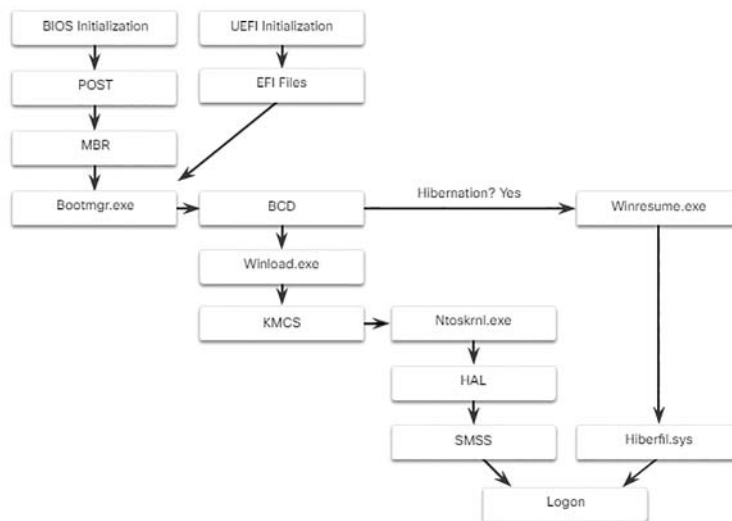


Figure 2-5 Windows Boot Process

The MBR contains a small program that is responsible for locating and loading the operating system. The BIOS executes this code and the operating system starts to load.

In contrast to BIOS firmware, UEFI firmware has a lot of visibility into the boot process. UEFI boots by loading EFI program files, stored as .efi files in a special disk partition, known as the EFI System Partition (ESP).

Note

A computer that uses UEFI stores boot code in the firmware. This helps to increase the security of the computer at boot time because the computer goes directly into protected mode.

Whether the firmware is BIOS or UEFI, after a valid Windows installation is located, the Bootmgr.exe file is run. Bootmgr.exe switches the system from real mode to protected mode so that all of the system memory can be used.

Bootmgr.exe reads the *Boot Configuration Database (BCD)*. The BCD contains any additional code needed to start the computer, along with an indication of whether the computer is coming out of hibernation, or if this is a cold start. If the computer

is coming out of hibernation, the boot process continues with Winresume.exe. This allows the computer to read the Hiberfil.sys file, which contains the state of the computer when it was put into hibernation.

If the computer is being booted from a cold start, then the Winload.exe file is loaded. The Winload.exe file creates a record of the hardware configuration in the registry. The registry is a record of all of the settings, options, hardware, and software the computer has. The registry will be explored in depth later in this chapter. Winload.exe also uses *Kernel Mode Code Signing (KMCS)* to make sure that all drivers are digitally signed. This ensures that the drivers are safe to load as the computer starts.

After the drivers have been examined, Winload.exe runs Ntoskrnl.exe, which starts the Windows kernel and sets up the HAL. Finally, the *Session Manager Subsystem (SMSS)* reads the registry to create the user environment, start the Winlogon service, and prepare each user's desktop as they log on.

Windows Startup and Shutdown (2.1.2.5)

There are two important registry items that are used to automatically start applications and services:

- **HKEY_LOCAL_MACHINE:** Several aspects of Windows configuration are stored in this key, including information about services that start with each boot.
- **HKEY_CURRENT_USER:** Several aspects related to the logged-in user are stored in this key, including information about services that start only when the user logs on to the computer.

Different entries in these registry locations define which services and applications will start, as indicated by their entry type. These types include Run, RunOnce, RunServices, RunServicesOnce, and Userinit. These entries can be manually entered into the registry, but it is much safer to use the Msconfig.exe tool. This tool is used to view and change all of the startup options for the computer. Use the search box to find and open the **Msconfig** tool.

There are five tabs which contain the configuration options:

- **General:** Three different startup types can be chosen here. Normal loads all drivers and services. Diagnostic loads only basic drivers and services. Selective allows the user to choose what to load on startup. The General tab is shown in Figure 2-6.

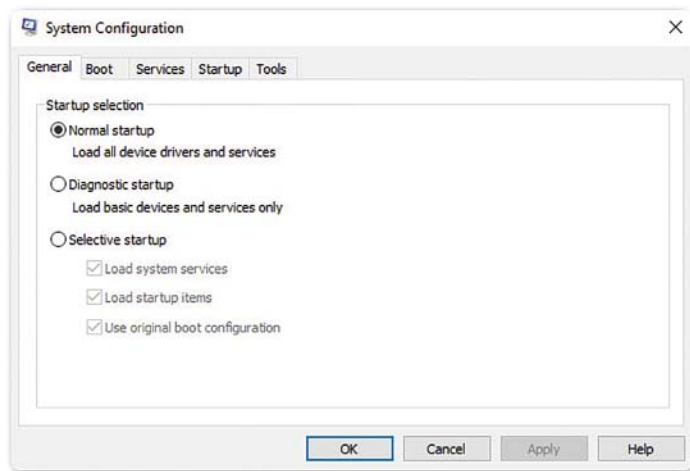


Figure 2-6 General Tab of System Configuration

- **Boot:** Any installed operating system can be chosen here to start. There are also options for Safe boot, which is used to troubleshoot startup. The Boot tab is shown in Figure 2-7.

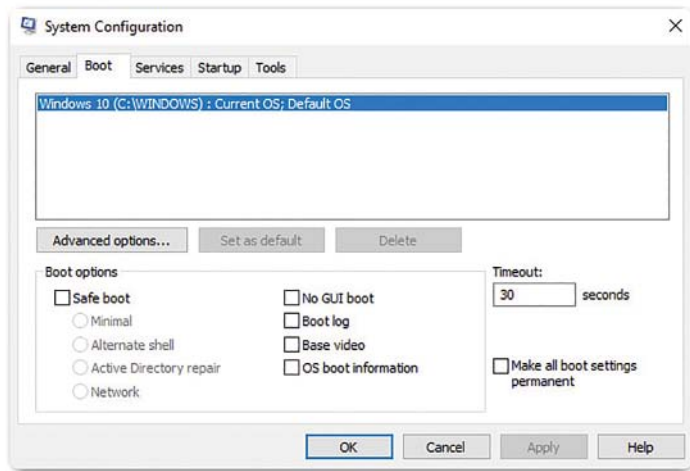


Figure 2-7 Boot Tab of System Configuration

- **Services:** All the installed services are listed here so that they can be chosen to start at startup. The Services tab is shown in Figure 2-8.

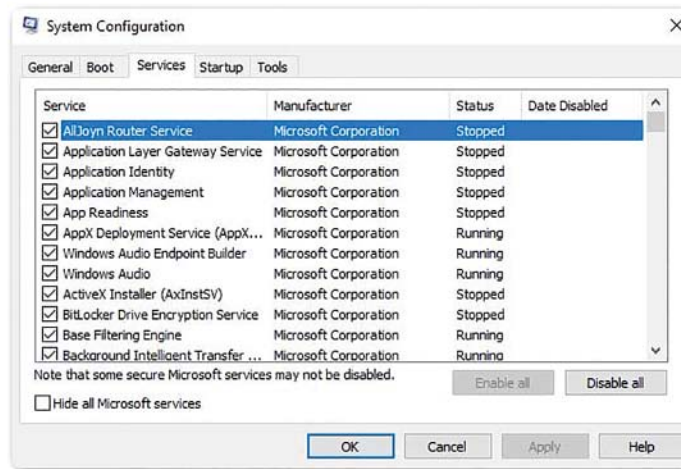


Figure 2-8 Services Tab of System Configuration

- **Startup:** All the applications and services that are configured to automatically begin at startup can be enabled or disabled by opening Task Manager from this tab. The Startup tab is shown in Figure 2-9.

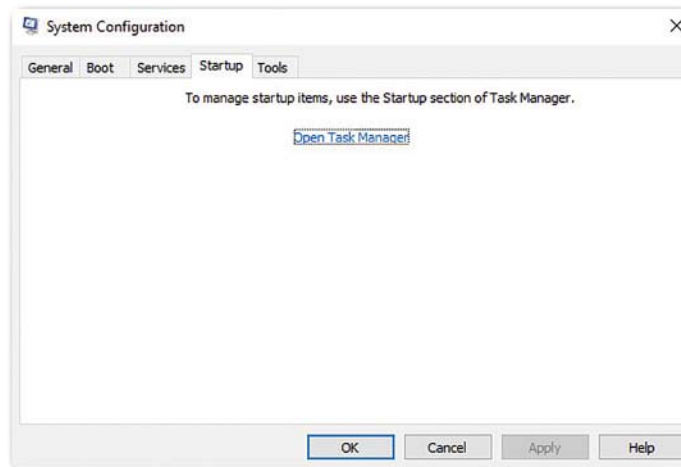


Figure 2-9 Startup Tab of System Configuration

- **Tools:** Many common operating system tools can be launched directly from this tab. The Tools tab is shown in Figure 2-10.

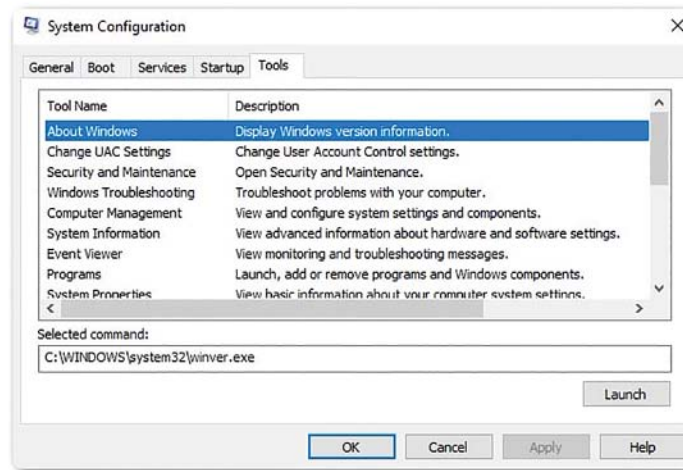


Figure 2-10 Tools Tab of System Configuration

Shutdown

It is always best to perform a proper shutdown to turn off the computer. Files that are left open, services that are closed out of order, and applications that hang can all be damaged if the power is turned off without first informing the operating system. The computer needs time to close each application, shut down each service, and record any configuration changes before power is lost.

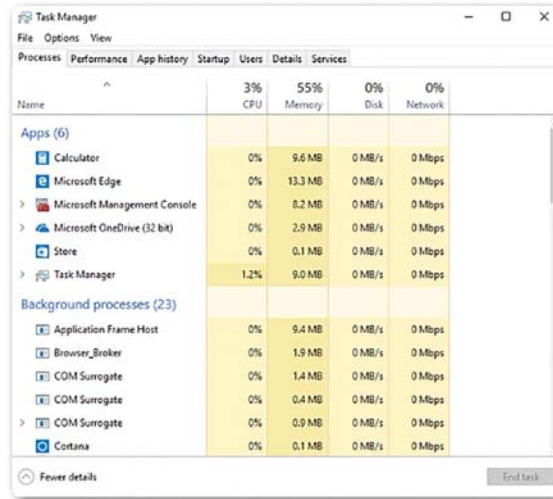
During shutdown, the computer will close user mode applications first, followed by kernel mode processes. If a user mode process does not respond within a certain amount of time, the OS will display notification and allow the user to wait for the application to respond, or forcibly end the process. If a kernel mode process does not respond, the shutdown will appear to hang, and it may be necessary to shut down the computer with the power button.

There are several ways to shut down a Windows computer: Start menu power options, the command line command **shutdown**, and using **Ctrl-Alt-Delete** and clicking the power icon. There are three different options from which to choose when shutting down the computer: Shutdown, which turns the computer off, Restart, which reboots the computer from scratch, and Hibernate, which records the current state of the computer and user environment and stores it in a file. Hibernation allows the user to pick up right where they left off very quickly with all their files and programs still open.

Processes, Threads, and Services (2.1.2.6)

A Windows application is made up of *processes*. The application can have one or many processes dedicated to it. A process is any program that is currently executing.

Each process that runs is made up of at least one *thread*. A thread is a part of the process that can be executed. The processor performs calculations on the thread. To configure Windows processes, search for **Task Manager**. The Processes tab of Task Manager is shown in Figure 2-11.



Name	3% CPU	55% Memory	0% Disk	0% Network
Apps (6)				
Calculator	0%	9.6 MB	0 MB/s	0 Mbps
Microsoft Edge	0%	13.3 MB	0 MB/s	0 Mbps
Microsoft Management Console	0%	8.2 MB	0 MB/s	0 Mbps
Microsoft OneDrive (32 bit)	0%	2.9 MB	0 MB/s	0 Mbps
Store	0%	0.1 MB	0 MB/s	0 Mbps
Task Manager	1.2%	9.0 MB	0 MB/s	0 Mbps
Background processes (23)				
Application Frame Host	0%	6.4 MB	0 MB/s	0 Mbps
Browser_Broker	0%	1.9 MB	0 MB/s	0 Mbps
COM Surrogate	0%	1.4 MB	0 MB/s	0 Mbps
COM Surrogate	0%	0.4 MB	0 MB/s	0 Mbps
COM Surrogate	0%	0.9 MB	0 MB/s	0 Mbps
Cortana	0%	0.1 MB	0 MB/s	0 Mbps

Figure 2-11 Windows Task Manager Processes Tab

All of the threads dedicated to a process are contained within the same address space. This means that these threads may not access the address space of any other process. This prevents corruption of other processes. Because Windows multi-tasks, multiple threads can be executed at the same time. The number of threads that can be executed at the same time is dependent on how many processors the computer has.

Some of the processes that Windows runs are *services*. These are programs that run in the background to support the operating system and applications. They can be set to start automatically when Windows boots or they can be started manually. They can also be stopped, restarted, or disabled. Services provide long-running functionality, such as wireless or access to an FTP server. To configure Windows Services, search for **services**. The Windows Services control panel applet is shown in Figure 2-12. Be very careful when manipulating the setting of these services. Some programs rely on one or more services to operate properly. Shutting down a service may adversely affect applications, or other services.

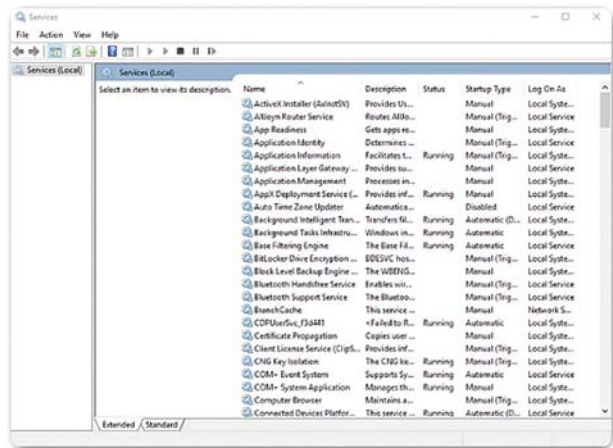


Figure 2-12 Windows Services Control Panel Applet

Memory Allocation and Handles (2.1.2.7)

A computer works by storing instructions in RAM until the CPU processes them. The virtual address space for a process is the set of virtual addresses that the process can use. The virtual address is not the actual physical location in memory, but an entry in a page table that is used to translate the virtual address into the physical address.

Each process in a 32-bit Windows computer supports a virtual address space that enables addressing up to 4 gigabytes. Each process in a 64-bit Windows computer supports a virtual address space of 8 terabytes.

Each user space process runs in a private address space, separate from other user space processes. When the user space process needs to access kernel resources, it must use a process handle. This is because the user space process is not allowed to directly access these kernel resources. The process handle provides the access needed by the user space process without a direct connection to it.

One of the more powerful tools we use to view memory allocation is Sysinternals RamMap, shown in Figure 2-13.

The Windows Registry (2.1.2.8)

Windows stores all of the information about hardware, applications, users, and system settings in a large database known as the *registry*. The ways that these objects interact are also recorded, such as what files an application opens and all of the property details of folders and applications. The registry is a hierarchical database where

the highest level is known as a hive, below which are keys, followed by subkeys. Values, which store data, are stored in keys and subkeys. The registry key can be up to 512 levels deep.

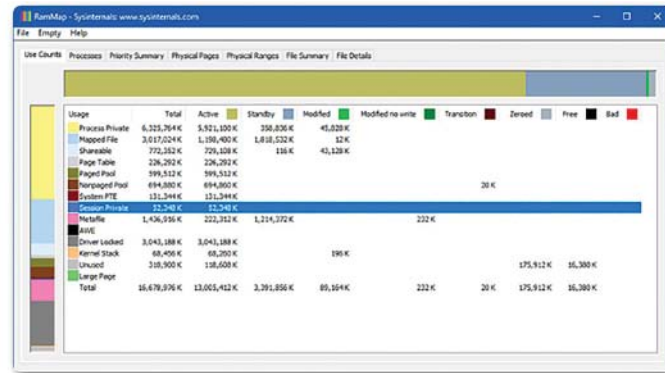


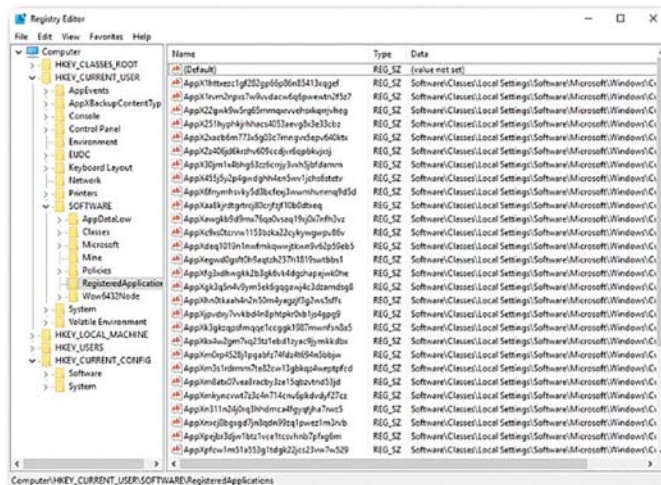
Figure 2-13 Sysinternals RamMap

These are the five hives of the Windows registry:

- **HKEY_CURRENT_USER (HKCU):** Holds data concerning the currently logged-in user
- **HKEY_USERS (HKU):** Holds data concerning all the user accounts on the host
- **HKEY_CLASSES_ROOT (HKCR):** Holds data about object linking and embedding (OLE) registrations
- **HKEY_LOCAL_MACHINE (HKLM):** Holds system-related data
- **HKEY_CURRENT_CONFIG (HKCC):** Holds data about the current hardware profile

New hives cannot be created. The registry keys and values in the hives can be created, modified, or deleted by an account with administrative privileges. As shown in Figure 2-14, the tool regedit.exe is used to modify the registry. Be very careful when using this tool. Minor changes to the registry can have massive or even catastrophic effects.

Navigation in the registry is very similar to navigation in Windows File Explorer. Use the left panel to navigate the hives and the structure below it, and use the right panel to see the contents of the highlighted item in the left panel. With so many keys and subkeys, the key path can become very long. The path is displayed at the bottom of the window for reference. Because each key and subkey is essentially a container, the path is represented much like a folder in a file system. The backslash (\) is used to differentiate the hierarchy of the database.

**Figure 2-14** Windows Registry Editor

Registry keys can contain either a subkey or a value. These are the different values that keys can contain:

- **REG_BINARY:** Numbers or Boolean values
- **REG_DWORD:** Numbers greater than 32 bits or raw data
- **REG_SZ:** String values

Because the registry holds almost all the operating system and user information, it is critical to make sure that it does not become compromised. Potentially malicious applications can add registry keys so that they start when the computer is started. During a normal boot, the user will not see the program start because the entry is in the registry and the application displays no windows or indication of starting when the computer boots. A keylogger, for example, would be devastating to the security of a computer if it were to start at boot without the user's knowledge or consent. When performing normal security audits, or remediating an infected system, review the application startup locations within the registry to ensure that each item is known and safe to run.

The registry also contains the activity that a user performs during normal day-to-day computer use. This includes the history of hardware devices, including all devices that have been connected to the computer, identified by name, manufacturer, and serial number. Other information, such as what documents a user and program have opened, where they are located, and when they were accessed, is stored in the registry. This is all very useful information when a forensic investigation needs to be performed.

**Interactive
Graphic****Activity 2.1.2.9: Identify the Windows Registry Hive**

Refer to the online course to complete this Activity.

**Lab 2.1.2.10: Exploring Processes, Threads, Handles, and Windows Registry**

In this lab, you will explore the processes, threads, and handles using Process Explorer in Sysinternals Suite. You will also use the Windows registry to change a setting.

Windows Administration (2.2)

In this section, you will learn about Windows configuration, monitoring, and security.

Windows Configuration and Monitoring (2.2.1)

In this topic, you will learn about Windows configuration management, including running applications as the Administrator, configuring local users and domains, and working with the command line interface (CLI), PowerShell, and Windows Management Instrumentation (WMI). You will also learn how to monitor Windows using the **net** command, Task Manager, Resource Monitor, and networking tools.

Run as Administrator (2.2.1.1)

As a security best practice, it is not advisable to log on to Windows using the Administrator account or an account with administrative privileges. This is because any program that is executed while logged on with those privileges will inherit them. Malware that has administrative privileges has full access to all the files and folders on the computer.

Sometimes, it is necessary to run or install software that requires the privileges of the Administrator. To accomplish this, there are two different ways to install it:

- **Run as Administrator:** Right-click the command in Windows File Explorer and choose **Run as administrator** from the Context Menu, shown in Figure 2-15.
- **Administrator Command Prompt:** Search for **command**, right-click the executable file, and choose **Run as administrator** from the Context Menu, shown in Figure 2-16. Every command that is executed from this command line will be carried out with administrative privileges, including installation of software.

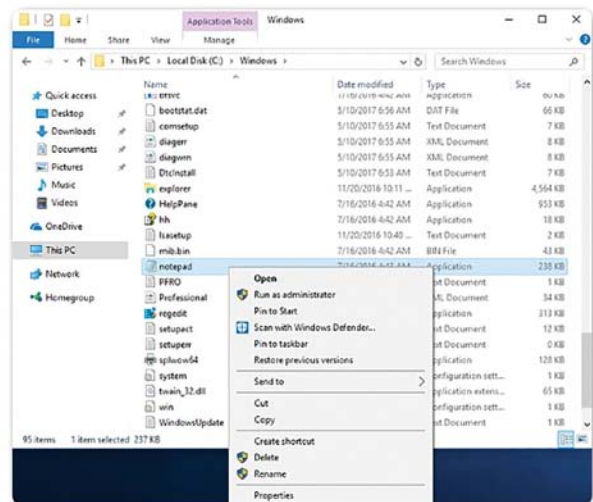


Figure 2-15 Run as Administrator from Windows File Explorer

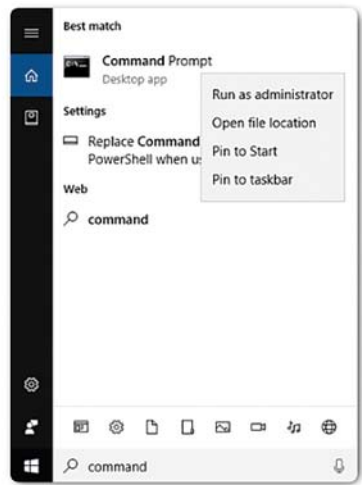


Figure 2-16 Run as Administrator Using Administrator Command Prompt

Local Users and Domains (2.2.1.2)

When you start a new computer for the first time, or you install Windows, you will be prompted to create a user account. This is known as a local user. This account will contain all of your customization settings, access permissions, file locations, and many other user-specific data. There are also two other accounts that are present: Guest and Administrator. Both of these accounts are disabled by default.

As a security best practice, do not enable the Administrator account and do not give standard users administrative privileges. If a user needs to perform any function that requires administrative privileges, the system will ask for the Administrator password and allow only that task to be performed as an administrator. By entering the Administrator password, this protects the computer by preventing any software that is not authorized from installing, executing, or accessing files.

The Guest account should not be enabled. The Guest account does not have a password associated with it because it is created when a computer is going to be used by many different people who do not have accounts on the computer. Each time the Guest account logs on, a default environment is provided to them with limited privileges.

To make administration of users easier, Windows uses groups. A group will have a name and a specific set of permissions associated with it. When a user is placed into a group, the permissions of that group are given to that user. A user can be placed into multiple groups to be provided with many different permissions. When the permissions overlap, certain permissions, like “explicitly deny,” will override the permission provided by a different group. There are many different user groups built in to Windows that are used for specific tasks. For example, the Performance Log Users group allows members to schedule logging of performance counters and collect logs either locally or remotely. Local users and groups are managed with the `lusrmgr.msc` control panel applet, as shown in Figure 2-17.

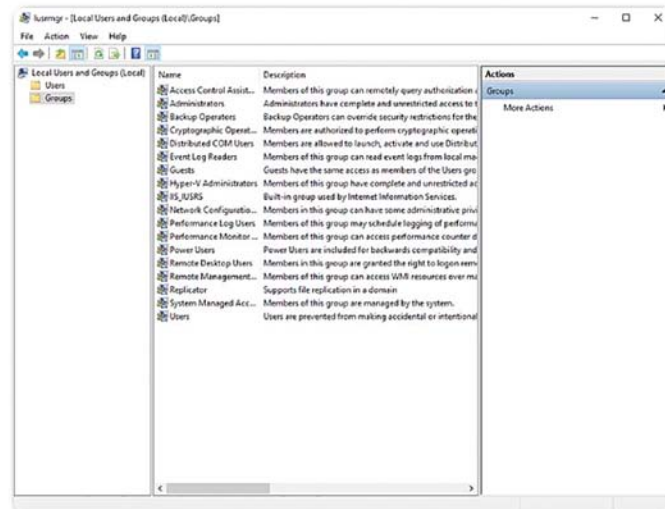


Figure 2-17 lusrmgr.msc

In addition to groups, Windows can also use domains to set permissions. A *domain* is a type of network service where all of the users, groups, computers, peripherals, and security settings are stored on and controlled by a database. This database is stored on special computers or groups of computers called *domain controllers (DCs)*. Each user and computer on the domain must authenticate against the DC to log on and access network resources. The security settings for each user and each computer are set by the DC for each session. Any setting supplied by the DC defaults to the local computer or user account setting.

CLI and PowerShell (2.2.1.3)

The Windows *command line interface (CLI)* can be used to run programs, navigate the file system, and manage files and folders. In addition, files called batch files can be created to execute multiple commands in succession, much like a basic script. To open the Windows CLI, search for **cmd.exe** and click the program. Remember that right-clicking the program provides the option to Run as Administrator, giving much more power to the commands that will be used.

The prompt displays the current location within the file system. These are a few things to remember when using the CLI:

- The filenames and paths are not case sensitive, by default.
- Storage devices are assigned a letter for reference. The letter, followed by a backslash (\), indicates the root of the device. Folder and file hierarchy on the device is indicated by separating them with the backslash. For example, C:\Users\Jim\Desktop\file.txt is the file called file.txt in the Desktop folder within the Jim folder within the Users folder on the device C:.
- Commands that have optional switches use the forward slash (/) to delineate between the command and each switch.
- You can use the Tab key to auto-complete commands when directories or files are referenced.
- Windows keeps a history of the commands that were entered during a CLI session. Access historical commands by using the Up Arrow and Down Arrow keys.
- To switch between storage devices, type the letter of the device, followed by a colon, and then press Enter.

Even though the CLI has many commands and features, it cannot work together with the core of Windows or the GUI. Another environment, called the Windows *PowerShell*, can be used to create scripts to automate tasks that the regular CLI is unable to create. PowerShell also provides a CLI for initiating commands. PowerShell